

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

目錄：

介紹	3
1 適用範圍	6
2 引用標準	6
3 用語及定義	6
4 組織全景	13
4.1 理解組織及其全景	13
4.2 瞭解關注方之需要及期望	14
4.3 確定人工智慧管理系統的範圍	14
4.4 人工智慧管理系統	15
5 領導作為	15
5.1 領導及承諾	15
5.2 人工智慧政策	16
5.3 角色、責任和權限	16
6 規劃	17
6.1 因應風險及機會之行動	17
6.1.1 一般要求	17
6.1.2 人工智慧風險評鑑	18
6.1.3 人工智慧風險處理	19
6.1.4 人工智慧系統衝擊評鑑	20
6.2 人工智慧目標及其達成之規劃	21
6.3 變更之規劃	21
7 支援	22
7.1 資源	22
7.2 能力	22
7.3 認知	22
7.4 溝通或傳達	23

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

7.5 文件化資訊.....	23
7.5.1 一般要求	23
7.5.2 制訂及更新文件化資訊	23
7.5.3 文件化資訊之控制	24
8 運作	24
8.1 運作之規劃及控制.....	24
8.2 人工智慧風險評鑑.....	25
8.3 人工智慧風險處理.....	25
8.4 人工智慧系統衝擊評鑑.....	25
9 績效評估	26
9.1 監督、量測、分析及評估.....	26
9.2 內部稽核.....	26
9.2.1 一般要求	26
9.2.2 內部稽核方案	26
9.3 管理審查.....	27
9.3.1 一般要求	27
9.3.2 管理審查輸入	27
9.3.3 管理審查結果	27
10 改善.....	28
10.1 持續改善.....	28
10.2 不符合事項及矯正措施.....	28
附錄 A (規範性) 參考控制目標與控制措施.....	29
附錄 B (規範性) 人工智慧控制措施之實作指引.....	38
附錄 C (資訊性) 潛在與人工智慧相關的組織目標和風險來源.....	75
附件 D (資訊性) 人工智慧管理系統在各領域或行業中的應用.....	78
參考書目	81

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Information technology — Artificial intelligence — Management system

Introduction

Artificial intelligence (AI) is increasingly applied across all sectors utilizing information technology and is expected to be one of the main economic drivers. A consequence of this trend is that certain applications can give rise to societal challenges over the coming years.

This document intends to help organizations responsibly perform their role with respect to AI systems (e.g. to use, develop, monitor or provide products or services that utilize AI). AI potentially raises specific considerations such as:

- The use of AI for automatic decision-making, sometimes in a non-transparent and non-explainable way, can require specific management beyond the management of classical IT systems.
- The use of data analysis, insight and machine learning, rather than human-coded logic to design systems, both increases the application opportunities for AI systems and changes the way that such systems are developed, justified and deployed.
- AI systems that perform continuous learning change their behaviour during use. They require special consideration to ensure their responsible use continues with changing behaviour.

This document provides requirements for establishing, implementing, maintaining and continually improving an AI management system within the context of an organization. Organizations are expected to focus their application of requirements on features that are unique to AI. Certain features of AI, such as the ability to continuously learn and improve or a lack of transparency or explainability, can warrant different safeguards if they raise additional concerns compared to how the task would traditionally be performed. The adoption of an AI management system to extend the existing management structures is a strategic decision for an organization.

資訊科技 — 人工智慧 — 管理系統

介紹

人工智慧 (AI) 越來越多地應用於利用資訊技術的各個領域，預計將成為主要的經濟驅動力之一。這一趨勢的結果是，某些應用程式可能會在未來幾年引發社會挑戰。

本文件旨在幫助組織負責任地履行其在人工智慧系統方面的角色 (例如使用、開發、監督或提供利用人工智慧的產品或服務)。人工智慧可能會提出具體的考慮因素，例如：

- 使用人工智慧進行自動決策，有時以不透明和不可解釋的方式進行，可能需要超越傳統 IT 系統管理的具體管理。
- 使用資料分析、洞察力和機器學習，而不是人類編碼的邏輯來設計系統，既增加了人工智慧系統的應用機會，又改變了此類系統的開發、論證和部署方式。
- 執行持續學習的人工智慧系統會在使用流程中改變其行為。他們需要特別考量，以確保他們在行為的改變時仍持續地負責任使用著。

本文件提供了在組織範圍內建立、實作、維持和持續改善人工智慧管理系統的要求事項。組織應將其要求事項的應用重點放在人工智慧獨有的功能上。人工智慧的某些特徵，例如持續學習和改進的能力或缺乏透明性或可解釋性，如果與傳統的任務執行方式相比引起了額外的擔憂，則可以採取不同的保護措施。採用人工智慧管理系統來擴展現有的管理結構是組織的策略決策。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

The organization's needs and objectives, processes, size and structure as well as the expectations of various interested parties influence the establishment and implementation of the AI management system. Another set of factors that influence the establishment and implementation of the AI management system are the many use cases for AI and the need to strike the appropriate balance between governance mechanisms and innovation. Organizations can elect to apply these requirements using a risk-based approach to ensure that the appropriate level of control is applied for the particular AI use cases, services or products within the organization's scope. All these influencing factors are expected to change and be reviewed from time to time.

The AI management system should be integrated with the organization's processes and overall management structure. Specific issues related to AI should be considered in the design of processes, information systems and controls. Crucial examples of such management processes are:

- determination of organizational objectives, involvement of interested parties and organizational policy;
- management of risks and opportunities;
- processes for the management of concerns related to the trustworthiness of AI systems such as security, safety, fairness, transparency, data quality and quality of AI systems throughout their life cycle;
- processes for the management of suppliers, partners and third parties that provide or develop AI systems for the organization.

This document provides guidelines for the deployment of applicable controls to support such processes.

This document avoids specific guidance on management processes. The organization can combine generally accepted frameworks, other International Standards and its own experience to implement crucial processes such as risk management, life cycle management and data quality management which are appropriate for the specific AI use cases, products or services within the scope.

An organization conforming with the requirements in this document can generate evidence of its responsibility and accountability regarding its role with respect to AI systems.

組織的要求和目標、各項流程、規模和結構以及各關注方的期望影響人工智慧管理體系的建立和實作。影響人工智慧管理系統建立和實作的另一組因素是人工智慧的眾多使用案例以及需要在治理機制和創新之間取得適當的平衡。組織可以選擇使用基於風險的方法來應用這些要求事項，以確保對特定的情況應用適當的控制層級。組織範圍內的人工智慧使用案例、服務或產品。所有這些影響因素預計都會發生變化並不時進行審查。

人工智慧管理系統宜與組織之各項流程和整體管理結構整合。在各項流程、資訊系統和控制的設計中宜考慮與人工智慧相關的具體議題。此類管理流程的重要範例包括：

- 確定組織目標、關注方的參與和組織政策；
- 風險和機會的管理；
- 管理與人工智慧系統可信性相關的議題的各項流程，例如人工智慧系統整個生命週期的資安、安全性、公平性、透明性、資料品質和人工智慧系統品質；
- 為組織提供或開發人工智慧系統的供應商、合作夥伴和第三方的管理各項流程。
- 本文件提供了相關控制措施部署的指導綱要原則，以支持各項流程。

本文件避免了對管理流程的具體指導。組織可以結合普遍接受的框架、其他國際標準和自身經驗來實施適合範圍內特定人工智慧使用案例、產品或服務的各項關鍵流程，例如風險管理、生命週期管理和資料品質管理。

符合本文件要求事項的組織可以產生其在人工智慧系統方面的角色和責任及當責性的證據。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

The order in which requirements are presented in this document does not reflect their importance or imply the order in which they are implemented. The list items are enumerated for reference purposes only.

Compatibility with other management system standards

This document applies the harmonized structure (identical clause numbers, clause titles, text and common terms and core definitions) developed to enhance alignment among management system standards (MSS). The AI management system provides requirements specific to managing the issues and risks arising from using AI in an organization. This common approach facilitates implementation and consistency with other management system standards, e.g. related to quality, safety, security and privacy.

本文檔中提出要求的順序並不反映其重要性或暗示其實施順序。列舉的列表項目僅供參考。

與其他管理系統標準的兼容性

本文件應用了為加強管理系統標準 (MSS) 之間的一致性而開發的調和性結構 (相同的條款編號、條款標題、文本和通用術語以及核心定義)。人工智慧管理系統提供管理議題的具體要求事項以及在組織中使用人工智慧所產生的風險。這種通用方法有助於實施並與其他管理系統標準保持一致，例如：涉及品質、安全、資安和隱私。

訓練專用 禁止翻印

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Information technology — Artificial intelligence — Management system

1 Scope

This document specifies the requirements and provides guidance for establishing, implementing, maintaining and continually improving an AI (artificial intelligence) management system within the context of an organization.

This document is intended for use by an organization providing or using products or services that utilize AI systems. This document is intended to help the organization develop, provide or use AI systems responsibly in pursuing its objectives and meet applicable requirements, obligations related to interested parties and expectations from them.

This document is applicable to any organization, regardless of size, type and nature, that provides or uses products or services that utilize AI systems.

2 Normative references

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

ISO/IEC 22989:2022, Information technology — Artificial intelligence — Artificial intelligence concepts and terminology

3 Terms and definitions

For the purposes of this document, the following terms and definitions apply.

ISO and IEC maintain terminological databases for use in standardization at the following addresses:

- ISO Online browsing platform: available at <https://www.iso.org/obp>
- IEC Electropedia: available at <http://www.electropedia.org/>

資訊科技 — 人工智慧 — 管理系統

1 適用範圍

本文件規定於組織全景內建立、實作、維持及持續改善人工智慧管理系統之要求事項。

本文件旨在供提供或使用人工智慧系統產品或服務的組織之使用。本文件旨在幫助組織在追求其目標時，進行負責任開發、提供或使用人工智慧系統，並滿足適用的要求事項、與關注方的義務以及其期望。

本文件適用於任何提供或使用人工智慧系統產品或服務的組織，不論其規模、形式或性質。

2 引用標準

本文件中引用以下標準並使它們的部分或全部內容構成本文檔的事項。已標註日期的引用文件，僅適用所引用的版本。未標註日期的引用文件，適用其最新版本（含所有補充增修）。

ISO/IEC 22989:2022，資訊科技 — 人工智慧 — 人工智慧概念及詞彙。

3 用語及定義

所規定之用語及定義適用於本文件。

ISO 與 IEC 標準用語資料庫維護於以下網址：

- ISO 線上瀏覽平台：<https://www.iso.org/obp>
- IEC 電子百科全書：<http://www.electropedia.org/>

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

3.1 Organization

person or group of people that has its own functions with responsibilities, authorities and relationships to achieve its objectives (3.6)

Note 1 to entry: The concept of organization includes, but is not limited to, sole-trader, company, corporation, firm, enterprise, authority, partnership, charity or institution or part or combination thereof, whether incorporated or not, public or private.

Note 2 to entry: If the organization is part of a larger entity, the term "organization" refers only to the part of the larger entity that is within the scope of the AI management system (3.4).

3.2 interested party

person or organization (3.1) that can affect, be affected by, or perceive itself to be affected by a decision or activity

Note 1 to entry: An overview of interested parties in AI is provided in ISO/IEC 22989:2022, 5.19.

3.3 top management

person or group of people who directs and controls an organization (3.1) at the highest level

Note 1 to entry: Top management has the power to delegate authority and provide resources within the organization.

Note 2 to entry: If the scope of the management system (3.4) covers only part of an organization, then top management refers to those who direct and control that part of the organization.

3.4 management system

set of interrelated or interacting elements of an organization (3.1) to establish policies (3.5) and objectives (3.6), as well as processes (3.8) to achieve those objectives

Note 1 to entry: A management system can address a single discipline or several disciplines.

Note 2 to entry: The management system elements include the organization's structure, roles and responsibilities, planning and operation.

3.1 組織

為達成其目標 (3.6) 而具有責任、權限及關係之本身功能的個人或一群人。

註釋 1 組織之概念包括但不僅限於自營商、公司、集團、商行、企業、官方機構、合夥企業、慈善團體或機構，或其部分或組合，不論是否為法人，公有或私有。

註釋 2 如果組織是更大實體的一部分，則「組織」一詞僅指在人工智慧管理系統 (3.4) 範圍內的較大實體的部分。

3.2 關注方

可影響、受影響，或知覺本身將受決策或活動影響之個人或組織 (3.1)。

註釋 1 ISO/IEC 22989:2022，5.19 中提供了人工智慧關注方之概述。

3.3 最高管理階層

於最高層級指導與控制組織 (3.1) 的個人或群體。

註釋 1 最高管理階層有權在組織內授權和提供資源。

註釋 2 如果管理系統 (3.4) 的範圍僅涵蓋組織的一部分，則最高管理階層意指那些提供指導與掌控該部分組織的人。

3.4 管理系統

一套相互關聯或交互作用的要素，組織 (3.1) 用以建立政策政策 (3.5) 和目標 (3.6)，以及用以建立達成該等目標之各項流程 (3.8)。

註釋 1 一個管理系統可處理單一專業領域或多個專業領域。

註釋 2 管理系統的要素包括組織結構、角色和責任、規劃與營運。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

3.5 policy

intentions and direction of an *organization* (3.1) as formally expressed by its *top management* (3.3)

3.6 objective

result to be achieved

Note 1 to entry: An objective can be strategic, tactical, or operational.

Note 2 to entry: Objectives can relate to different disciplines (such as finance, health and safety, and environment). They can be, for example, organization-wide or specific to a project, product or process (3.8).

Note 3 to entry: An objective can be expressed in other ways, e.g. as an intended result, as a purpose, as an operational criterion, as an AI objective or by the use of other words with similar meaning (e.g. aim, goal, or target).

Note 4 to entry: In the context of AI management systems (3.4), AI objectives are set by the organization (3.1), consistent with the AI policy (3.5), to achieve specific results.

3.7 risk

effect of uncertainty

Note 1 to entry: An effect is a deviation from the expected — positive or negative.

Note 2 to entry: Uncertainty is the state, even partial, of deficiency of information related to, understanding or knowledge of, an event, its consequence, or likelihood.

Note 3 to entry: Risk is often characterized by reference to potential events (as defined in ISO Guide 73) and consequences (as defined in ISO Guide 73), or a combination of these.

Note 4 to entry: Risk is often expressed in terms of a combination of the consequences of an event (including changes in circumstances) and the associated likelihood (as defined in ISO Guide 73) of occurrence.

3.8 process

set of interrelated or interacting activities that uses or transforms inputs to deliver a result

Note 1 to entry: Whether the result of a process is called an output, a product or a service depends on the context of the reference.

3.5 政策

由組織 (3.1) 的最高管理階層 (3.3) 所正式表達之意圖與方向。

3.6 目標

要實現的結果

註釋 1 目標可以是策略目標、戰術目標或營運目標。

註釋 2 目標可能與不同專業領域有關 (例：財務、安全衛生及環境目標)，且可應用在不同層面，例：全組織、專案、產品及流程 (3.8)。

註釋 3 目標可以用其他方式表達，例如作為預期結果、目的、操作標準、人工智慧目標，或使用具有類似含義的詞 (如目的、目標、指標)。

註釋 4 在人工智慧管理系統 (3.4) 的情況下，人工智慧目標由組織 (3.1) 設定，並與人工智慧政策 (3.5) 一致，以實現特定結果。

3.7 風險

不確定性之影響。

註釋 1 影響係指對預期值之正向或負向偏離。。

註釋 2 不確定性係資訊偏頗或不足之狀態，與事件、其後果或可能性之瞭解或知識相關。

註釋 3 風險通常通過參考潛在事件 (如 ISO Guide 73 中定義) 和後果 (如 ISO Guide 73 中定義)，或這些的組合來表徵。

註釋 4 風險通常以事件後果 (包括情況變化) 和發生的相關可能性 (如 ISO Guide 73 中定義) 的組合來表達。

3.8 流程

一組使用投入以交付預期結果的相互關聯或交互作用活動。

註釋 1 流程之結果稱之為產出、產品或服務，依據其所有關的全景而定。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

3.9 competence

ability to apply knowledge and skills to achieve intended results

3.10 documented information

information required to be controlled and maintained by an organization (3.1) and the medium on which it is contained.

Note 1 to entry: Documented information can be in any format and media and from any source.

Note 2 to entry: Documented information can refer to:

- the management system (3.4), including related processes (3.8);
- information created in order for the organization to operate (documentation);
- evidence of results achieved (records).

3.11 performance

measurable result

Note 1 to entry: Performance can relate either to quantitative or qualitative findings.

Note 2 to entry: Performance can relate to managing activities, processes (3.8), products, services, systems or organizations (3.1).

Note 3 to entry: In the context of this document, performance refers both to results achieved by using AI systems and results related to the AI management system (3.4). The correct interpretation of the term is clear from the context of its use.

3.12 continual improvement

recurring activity to enhance performance (3.11)

3.13 effectiveness

extent to which planned activities are realized and planned results are achieved

3.9 能力

運用知識及技能達成所預期結果之能力。

3.10 文件化資訊

被要求由組織 (3.1) 控制及維護之資訊，以及其所處的媒介。

註釋 1 文件化資訊，能採任何格式及媒體，且能來自任何來源。

註釋 2 文件化資訊可以指：

- 管理系統 (3.4)，包括相關各項流程 (3.8)；
- 供組織運作所產生之資訊 (文件化)；
- 達成結果之證據 (紀錄)。

3.11 績效

可量測的結果。

註釋 1 績效能與定量或定性之量測結果相關。

註釋 2 績效可以與管理活動、各項流程 (3.8)、產品、服務、系統或組織 (3.1) 相關。

註釋 3 於本文件的情況下，績效既指通過使用人工智慧系統所取得的結果，也指與人工智慧管理系統 (3.4) 相關的結果。該詞彙的正確解釋應依據使用的情境而明確表達。

3.12 持續改善

用以提升績效 (3.11) 的經常性活動。

3.13 有效性

實現所規劃活動並達成所規劃結果之程度。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

3.14 requirement

need or expectation that is stated, generally implied or obligatory

Note 1 to entry: "Generally implied" means that it is custom or common practice for the organization (3.1) and interested parties (3.2) that the need or expectation under consideration is implied.

Note 2 to entry: A specified requirement is one that is stated, e.g. in documented information (3.10).

3.15 conformity

fulfilment of a requirement (3.14)

3.16 nonconformity

non-fulfilment of a requirement (3.14)

3.17 corrective action

action to eliminate the cause(s) of a nonconformity (3.16) and to prevent recurrence

3.18 audit

systematic and independent process (3.8) for obtaining evidence and evaluating it objectively to determine the extent to which the audit criteria are fulfilled

Note 1 to entry: An audit can be an internal audit (first party) or an external audit (second party or third party), and it can be a combined audit (combining two or more disciplines).

Note 2 to entry: An internal audit is conducted by the organization (3.1) itself, or by an external party on its behalf.

Note 3 to entry: "Audit evidence" and "audit criteria" are defined in ISO 19011.

3.19 measurement

process (3.8) to determine a value

3.20 monitoring

determining the status of a system, a process (3.8) or an activity

Note 1 to entry: To determine the status, there can be a need to check, supervise or critically observe.

3.14 要求事項

陳述之需求或期望，通常為隱含或強制。

註釋 1 “通常為隱含”意謂對組織 (3.1) 和關注方 (3.2)，係慣例或常用實務作法，其中考量中之需求或期望係隱含。

註釋 2 特定要求為所明確表述之要求事項，如於文件化資訊 (3.10)。

3.15 符合

滿足要求事項 (3.14)。

3.16 不符合

未滿足要求事項 (3.14)。

3.17 矯正措施

為消除不符合 (3.16) 的根本原因並防止其再次發生而採取的措施。

3.18 稽核

為有系統、獨立及文件化，獲取稽核證據，並客觀地評估，以決定稽核準則符合程度之流程 (3.8)。

註釋 1 稽核可為內部稽核 (第一方) 或外部稽核 (第二方或第三方)，且可為合併稽核 (合併兩項或多項專業領域)。

註釋 2 內部稽核由組織 (3.1) 自行進行，或由外部方代表其進行。

註釋 3 “稽核證據”和“稽核準則”定義於 ISO 19011。

3.19 量測

決定一個數值的流程 (3.8)。

3.20 監督

決定系統、流程 (3.8) 或活動的狀態。

註釋 1 決定狀態可能需要核對、監察或嚴謹觀察。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

3.21 control

<risk> measure that maintains and/or modifies risk (3.7)

Note 1 to entry: Controls include, but are not limited to, any process, policy, device, practice or other conditions and/or actions which maintain and/or modify risk.

Note 2 to entry: Controls may not always exert the intended or assumed modifying effect.

[SOURCE: ISO 31000:2018, 3.8, modified — Added <risk> as application domain]

3.22 governing body

person or group of people who are accountable for the performance and conformance of the organization

Note 1 to entry: Not all organizations, particularly small organizations, will have a governing body separate from top management.

Note 2 to entry: A governing body can include, but is not limited to, board of directors, committees of the board, supervisory board, trustees or overseers.

[SOURCE: ISO/IEC 38500:2015, 2.9, modified — Added Notes to entry.]

3.23 information security

preservation of confidentiality, integrity and availability of information

Note 1 to entry: Other properties such as authenticity, accountability, non-repudiation and reliability can also be involved.

[SOURCE: ISO/IEC 27000:2018, 3.28]

3.24 AI system impact assessment

formal, documented process by which the impacts on individuals, groups of individuals, or both, and societies are identified, evaluated and addressed by an organization developing, providing or using products or services utilizing artificial intelligence

3.25 data quality

characteristic of data that the data meet the organization's data requirements for a specific context

[SOURCE: ISO/IEC 5259-1:—1), 3.4]

3.21 控制措施

<風險> 維持和/或修改風險 (3.7) 的措施。

註釋 1 控制措施包括修改風險之所有過程、政策、裝置、實務或其他行動。

註釋 2 控制措施未必皆發揮所預期或所設想之修改效果。

[來源：ISO 31000:2018, 3.8, 修改 — 增加了<風險>作為應用領域]。

3.22 治理機構

負責組織之績效及符合性之個人或群體。

註釋 1 並非所有組織，特別是小型組織，皆有獨立於高層管理的治理機構。

註釋 2 治理機構可以包括但不限於董事會、董事會委員會、監事會、信託人或監管人。

[來源：ISO/IEC 38500:2015, 2.9, 修改 — 增加了備考]。

3.23 資訊安全

保障資訊的機密性、完整性和可用性。

註釋 1 其他相關可涉及之屬性如鑑別性、當責性、不可否認性和可靠性。

[來源：ISO/IEC 27000:2018, 3.28]。

3.24 人工智慧系統衝擊評鑑

以正式且文件化的流程，通過該流程，開發、提供或使用人工智慧產品或服務的組織識別、評估並處理對個人、群體或社會的衝擊。

3.25 資料品質

資料具備滿足組織對特定全景資料要求事項的特性。

[來源：ISO/IEC 5259-1:-1), 3.4]

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

3.26
statement of applicability

documentation of all necessary controls (3.23) and justification for inclusion or exclusion of controls

Note 1 to entry: Organizations may not require all controls listed in Annex A or may even exceed the list in Annex A with additional controls established by the organization itself.

Note 2 to entry: All identified risks shall be documented by the organization according to the requirements of this document. All identified risks and the risk management measures (controls) established to address them shall be reflected in the statement of applicability.

3.26
適用性聲明

文件化所有必要的控制措施 (3.23) 以及包含或排除這些控制措施的理由的文件。

註釋 1 組織可能不需要附錄 A 中列出的所有控制措施，或者甚至可以超過附錄 A 中的列表，採用組織自行建立的額外控制措施。

註釋 2 組織應根據本文件之要求事項，記錄所有已識別的風險。所有已識別的風險及為應將這些風險所建立的風險管理措施（控制措施）應反映在適用性聲明中。

訓練專用 禁止翻印

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

4 Context of the organization

4.1 Understanding the organization and its context

The organization shall determine external and internal issues that are relevant to its purpose and that affect its ability to achieve the intended result(s) of its AI management system.

The organization shall determine whether climate change is a relevant issue.

The organization shall consider the intended purpose of the AI systems that are developed, provided or used by the organization. The organization shall determine its roles with respect to these AI systems.

NOTE 1 To understand the organization and its context, it can be helpful for the organization to determine its role relative to the AI system. These roles can include, but are not limited to, one or more of the following:

— AI providers, including AI platform providers, AI product or service providers;

— AI producers, including AI developers, AI designers, AI operators, AI testers and evaluators, AI deployers, AI human factor professionals, domain experts, AI impact assessors, procurers, AI governance and oversight professionals;

— AI customers, including AI users;

— AI partners, including AI system integrators and data providers;

— AI subjects, including data subjects and other subjects;

— relevant authorities, including policymakers and regulators.

A detailed description of these roles is provided by ISO/IEC 22989. Furthermore, the types of roles and their relationship to the AI system life cycle are also described in the NIST AI risk management framework.[29] The organization's roles can determine the applicability and extent of applicability of the requirements and controls in this document.

NOTE 2 External and internal issues to be addressed under this clause can vary according to the organization's roles and jurisdiction and their impact on its ability to achieve the intended outcome(s) of its AI management system. These can include, but are not limited to:

a) external context related considerations such as:

- 1) applicable legal requirements, including prohibited uses of AI;
- 2) policies, guidelines and decisions from regulators that have an impact on the interpretation or enforcement of legal requirements in the development and use of AI

4 組織全景

4.1 瞭解組織及其全景

組織應決定及其目標有關且影響達成其人工智慧管理系統預期成果能力之外部及內部議題。

組織應決定氣候變遷是否為相關議題。

組織應考慮組織開發、提供或使用的人工智慧系統的預期用途，並應決定其在這些人工智慧系統中的角色。

備考 1 為組織決定其相對於人工智慧系統的角色，理解組織及其全景是有幫助的。這些角色可包括但不限以下一或多個：

— 人工智慧提供者，包括人工智慧平台提供者、人工智慧產品或服務提供者；

— 人工智慧製造者，包括人工智慧開發者、人工智慧設計師、人工智慧營運者、人工智慧測試員和評鑑員、人工智慧部署者、人工智慧人因工程專家、領域專家、人工智慧衝擊評鑑者、採購者、人工智慧治理和監管專業人士；

— 人工智慧客戶，包括人工智慧使用者；

— 人工智慧合作夥伴，包括人工智慧系統整合商和資料提供者；

— 人工智慧主體，包括資料主體和其他主體；

— 相關當局，包括政策制定者和監管機構。

ISO/IEC 22989 對這些角色進行了詳細描述。此外，這些角色的類型及其與人工智慧系統生命週期的關係也在 NIST AI 風險管理框架中進行了說明 [29]。組織的角色可以決定本文件中要求事項和控制措施的適用性及其適用性範圍。

備考 2 根據本條款應解決的外部 and 內部議題，會隨著組織的角色及其所在管轄區而有所不同，並影響其實現人工智慧管理系統預期結果的能力。這些議題可以包括但不限於：

a) 與外部全景相關的考量因素，如：

- 1) 適用的法律要求事項，包括禁止使用人工智慧的規定；
- 2) 影響人工智慧系統開發和使用的法律要求事項解釋或執行的監管政策、指引和決策；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

systems;

- 3)

incentives or consequences associated with the intended purpose and the use of AI systems;
- 4)

culture, traditions, values, norms and ethics with respect to development and use of AI;
- 5)

competitive landscape and trends for new products and services using AI systems;
- b)

internal context related considerations such as:

1)

organizational context, governance, objectives (see 6.2), policies and procedures;

2)

contractual obligations;

3)

intended purpose of the AI system to be developed or used.

NOTE 3 Role determination can be formed by obligations related to categories of data the organization processes (e.g. personally identifiable information (PII) processor or PII controller when processing PII). See ISO/IEC 29100 for PII and related roles. Roles can also be informed by legal requirements specific to AI systems.

4.2 Understanding the needs and expectations of interested parties

The organization shall determine:

- the interested parties that are relevant to the AI management system;
- the relevant requirements of these interested parties;
- which of these requirements will be addressed through the AI management system.

NOTE Relevant interested parties can have requirements related to climate change.

4.3 Determining the scope of the AI management system

The organization shall determine the boundaries and applicability of the AI management system to establish its scope.

When determining this scope, the organization shall consider:

- the external and internal issues referred to in 4.1;
- the requirements referred to in 4.2.

The scope shall be available as documented information.

- 3)

與人工智慧系統的預期用途和使用相關的激勵措施或後果；
- 4)

與 AI開發和使用相關的文化、傳統、價值觀、規範和倫理；
- 5)

使用人工智慧系統開發的新產品和服務的競爭格局和趨勢；
- b)

與內部全景相關的考量因素，如：

1)

組織全景、治理、目標（參見 6.2）、政策和程序；

2)

契約義務；

3)

預計開發或使用的人工智慧系統的預期用途。

備考 3 可以透過以組織處理的資料類別相關的義務來進行角色確立（例如，在處理個人識別資訊 (PII) 時，組織可能是 PII 處理者或 PII 控制者）。有關 PII 和相關角色，請參見 ISO/IEC 29100。角色也可以根據人工智慧系統特定的法律要求事項來確定。

4.2 瞭解關注方之需要及期望

組織應決定下列事項：

- 與人工智慧管理系統有關之關注各方；
- 此等關注方之相關要求事項；
- 其中哪些要求將透過人工智慧管理系統得到解決。

備考 相關關注方可能對氣候變遷有要求事項。

4.3 確定人工智慧管理系統的範圍

組織應決定人工智慧管理系統之邊界及適用性，以建立其範圍。

於決定範圍時，組織應考量下列事項：

- 4.1 中所提及之外部及內部議題。
- 4.2 中所提及之要求事項。

範圍應以文件化資訊提供。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

The scope of the AI management system shall determine the organization's activities with respect to this document's requirements on the AI management system, leadership, planning, support, operation, performance, evaluation, improvement, controls and objectives.

4.4 AI management system

The organization shall establish, implement, maintain, continually improve and document an AI management system, including the processes needed and their interactions, in accordance with the requirements of this document.

5 Leadership

5.1 Leadership and commitment

Top management shall demonstrate leadership and commitment with respect to the AI management system by:

- ensuring that the AI policy (see 5.2) and AI objectives (see 6.2) are established and are compatible with the strategic direction of the organization;
- ensuring the integration of the AI management system requirements into the organization's business processes;
- ensuring that the resources needed for the AI management system are available;
- communicating the importance of effective AI management and of conforming to the AI management system requirements;
- ensuring that the AI management system achieves its intended result(s);
- directing and supporting persons to contribute to the effectiveness of the AI management system;
- promoting continual improvement;
- supporting other relevant roles to demonstrate their leadership as it applies to their areas of responsibility.

NOTE 1 Reference to "business" in this document can be interpreted broadly to mean those activities that are core to the purposes of the organization's existence.

人工智慧管理系統的範圍應決定組織在本文件中對人工智慧管理系統、領導作為、規劃、支援、運作、績效、評估、改善、控制措施和目標的要求事項。

4.4 人工智慧管理系統

組織應根據本文件之要求事項，建立、實作、維持、持續改善並文件化人工智慧管理系統，包括其必要各項流程及相互作用。

5 領導作為

5.1 領導及承諾

最高管理階層應藉由下列事項，展現對人工智慧管理系統之領導及承諾：

- 確保已建立人工智慧政策（參見 5.2）和 AI 目標（參見 6.2），並與組織之策略方向相容；
- 確保人工智慧管理系統要求事項整合入組織之營運各項流程；
- 確保人工智慧管理系統所需資源可取得；
- 傳達有效之人工智慧管理的重要性，以及符合人工智慧管理系統要求事項之重要性；
- 確保人工智慧管理系統達成其預期結果；
- 指揮及支援人員，以促進人工智慧管理系統之有效性；
- 宣導持續改善；
- 當適用其他相關管理角色之責任範圍時，加以支持以展現其領導。

備考 1 本文件中之「業務」（business），可廣義地解釋為對組織存在的目的至關重要的活動。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

NOTE 2 Establishing, encouraging and modelling a culture within the organization, to take a responsible approach to using, development and governing AI systems can be an important demonstration of commitment and leadership by top management. Ensuring awareness of and compliance with such a responsible approach and in support of the AI management system through leadership can aid the success of the AI management system.

5.2 AI policy

Top management shall establish an AI policy that:

- a) is appropriate to the purpose of the organization;
- b) provides a framework for setting AI objectives (see 6.2);
- c) includes a commitment to meet applicable requirements;
- d) includes a commitment to continual improvement of the AI management system.

The AI policy shall:

- be available as documented information;
- refer as relevant to other organizational policies;
- be communicated within the organization;
- be available to interested parties, as appropriate.

Control objectives and controls for establishing an AI policy are provided in A.2 in Table A.1. Implementation guidance for these controls is provided in B.2.

NOTE Considerations for organizations when developing AI policies are provided in ISO/IEC 38507.

5.3 Roles, responsibilities and authorities

Top management shall ensure that the responsibilities and authorities for relevant roles are assigned and communicated within the organization.

Top management shall assign the responsibility and authority for:

- a) ensuring that the AI management system conforms to the requirements of this document;
- b) reporting on the performance of the AI management system to top management.

NOTE A control for defining and allocating roles and responsibilities is provided in A.3.2 in Table A.1. Implementation guidance for this control is provided in B.3.2.

備考 2 於組織內建立、鼓勵並樹立一種負責任之使用、開發與管理人工智慧系統的文化，為最高管理階層展現責任和領導的重要方式。通過領導來確保對這種負責任方法的認知與遵守，並支持人工智慧管理系統，可促使人工智慧管理系統的成功。

5.2 人工智慧政策

最高管理階層應建立包括下列事項之人工智慧政策：

- a) 適合於組織的目的；
- b) 提供設定人工智慧目標 (參見6.2) 使用之框架；
- c) 包括對滿足適用要求事項的承諾；
- d) 包括對持續改善人工智慧管理系統之承諾。

人工智慧政策應符合下列項目：

- 以文件化資訊提供；
- 參考與其他組織政策的相關性；
- 在組織內傳達；
- 適切時，提供予關注方。

建立人工智慧政策的控制目標和控制措施參見表 A.1 中的 A.2。

這些控制措施的實作指引參見 B.2。

備考 制定人工智慧政策時的考量事項參見 ISO/IEC 38507。

5.3 角色、責任及權限

最高管理階層應確保相關角色之責任及權限已指派，並於組織內傳達。

最高管理階層應指派下列責任及權限：

- a) 確保人工智慧管理系統符合本文件之要求事項；及
- b) 向最高管理階層報告人工智慧管理系統之績效。

備考 關於定義和分配角色與責任的控制措施參見表 A.1 中的 A.3.2。這些控制措施的實作指引參見 B.3.2。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

6 Planning

6.1 Actions to address risks and opportunities

6.1.1 General

When planning for the AI management system, the organization shall consider the issues referred to in 4.1 and the requirements referred to in 4.2 and determine the risks and opportunities that need to be addressed to:

- give assurance that the AI management system can achieve its intended result(s);
- prevent or reduce undesired effects;
- achieve continual improvement.

The organization shall establish and maintain AI risk criteria that support:

- distinguishing acceptable from non-acceptable risks;
- performing AI risk assessments;
- conducting AI risk treatment;
- assessing AI risk impacts.

NOTE 1 Considerations to determine the amount and type of risk that an organization is willing to pursue or retain are provided in ISO/IEC 38507 and ISO/IEC 23894.

The organization shall determine the risks and opportunities according to:

- the domain and application context of an AI system;
- the intended use;
- the external and internal context described in 4.1.

NOTE 2 More than one AI system can be considered in the scope of the AI management system. In this case the determination of opportunities and uses is performed for each AI system or groupings of AI systems.

The organization shall plan:

- a) actions to address these risks and opportunities;
- b) how to:

6 規劃

6.1 因應風險及機會之行動

6.1.1 一般要求

於規劃人工智慧管理系統時，組織應考量 4.1 所提及之議題及 4.2 所提及之要求事項，並決定需因應之風險與機會，以達成以下事項：

- 確保人工智慧管理系統達成其預期結果；
- 預防或減少非所欲之影響；
- 達成持續改善。

組織應建立並維持支持下列事項之人工智慧風險準則：

- 區分可接受和不可接受的風險；
- 執行人工智慧風險評鑑；
- 進行人工智慧風險處理；
- 評鑑人工智慧風險的衝擊。

備考 1 考量以決定組織可承擔或保留之風險數量與類型，請參考 ISO/IEC 38507 和 ISO/IEC 23894。

組織應根據以下因素決定風險與機會：

- 人工智慧系統的領域和應用全景；
- 預期用途；
- 4.1 中描述的外部 and 內部全景。

備考 2 人工智慧管理系統的範圍內可以包含多個人工智慧系統。在這種情況下，機會和用途的確定應針對每個人工智慧系統或人工智慧系統組合進行。

組織應規劃下列事項：

- a) 因應此等風險及機會之行動，及
- b) 執行下列事項之方法：

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

1) integrate and implement the actions into its AI management system processes;

2) evaluate the effectiveness of these actions.

The organization shall retain documented information on actions taken to identify and address AI risks and AI opportunities.

NOTE 3 Guidance on how to implement risk management for organizations developing, providing or using AI products, systems and services is provided in ISO/IEC 23894.

NOTE 4 The context of the organization and its activities can have an impact on the organization's risk management activities.

NOTE 5 The way of defining risk and therefore of envisioning risk management can vary across sectors and industries. The definition of risk in 3.7 allows a broad vision of risk adaptable to any sector, such as the sectors mentioned in Annex D. In any case, it is the role of the organization, as part of risk assessment, to first adopt a vision of risk adapted to its context. This can include approaching risk through definitions used in sectors where the AI system is developed for and used, such as the definition from ISO/IEC Guide 51.

6.1.2 AI risk assessment

The organization shall define and establish an AI risk assessment process that:

a) is informed by and aligned with the AI policy (see 5.2) and AI objectives (see 6.2);

NOTE When assessing the consequences as part of 6.1.2 d) 1), the organization can utilize an AI system impact assessment as indicated in 6.1.4.

b) is designed such that repeated AI risk assessments can produce consistent, valid and comparable results;

c) identifies risks that aid or prevent achieving its AI objectives;

d) analyses the AI risks to:

- 1) assess the potential consequences to the organization, individuals and societies that would result if the identified risks were to materialize;
- 2) assess, where applicable, the realistic likelihood of the identified risks;
- 3) determine the levels of risk;

1) 將各項行動整合及實作於人工智慧管理系統流程之中；以及

2) 評估此等行動之有效性。

組織應保留有關識別和應對人工智慧風險及人工智慧機會的行動的文件化資訊。

備考 3 有關為開發、提供或使用人工智慧產品、系統和服務的組織實施風險管理的指導參見 ISO/IEC 23894。

備考 4 組織全景和其活動會影響其風險管理活動。

備考 5 定義風險的方式以及因此設想風險管理的方式可能因行業而異。3.7 中的風險定義為一個開放的風險願景，可適用於任何行業，如附錄 D 中提到的行業。無論如何，作為風險評鑑的一部分，組織的角色應先採用符合其組織情況的風險願景。這可以包括透過人工智慧系統開發和使用的行業中使用的定義來處理風險，例如 ISO/IEC Guide 51 中的定義。

6.1.2 人工智慧風險評鑑

組織應定義並建立人工智慧風險評鑑流程於下列事項中：

a) 參考並與人工智慧政策（參見 5.2）和人工智慧目標（參見 6.2）一致；

備考 在 6.1.2 d) 1) 中作為評鑑後果的一部分，組織可以參考 6.1.4 中所指示的人工智慧系統衝擊評鑑。

b) 設計重複之人工智慧風險評鑑能產生一致、有效及可比較之結果；

c) 識別有助於或阻礙實現人工智慧目標的風險；

d) 分析人工智慧風險。

1) 評鑑若已識別風險實現時，對組織、個人和社會的潛在後果；

2) 評鑑已識別風險之發生可能性；

3) 決定風險等級；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

e) evaluates the AI risks to:

- 1) compare the results of the risk analysis with the risk criteria (see 6.1.1);
- 2) prioritize the assessed risks for risk treatment.

The organization shall retain documented information about the AI risk assessment process.

6.1.3 AI risk treatment

Taking the risk assessment results into account, the organization shall define an AI risk treatment process to:

- a) select appropriate AI risk treatment options;
- b) determine all controls that are necessary to implement the AI risk treatment options chosen and compare the controls with those in Annex A to verify that no necessary controls have been omitted;

NOTE 1 Annex A provides reference controls for meeting organizational objectives and addressing risks related to the design and use of AI systems.

c) consider the controls from Annex A that are relevant for the implementation of the AI risk treatment options;

d) identify if additional controls are necessary beyond those in Annex A in order to implement all risk treatment options;

e) consider the guidance in Annex B for the implementation of controls determined in b) and c);

NOTE 2 Control objectives are implicitly included in the controls chosen. The organization can select an appropriate set of control objectives and controls from Annex A. The Annex A controls are not exhaustive and additional control objectives and controls can be needed. If different or additional controls are necessary beyond those in Annex A, the organization can design such controls or take them from existing sources. AI risk management can be integrated in other management systems, if applicable.

f) produce a statement of applicability that contains the necessary controls [see b), c) and d)] and provide justification for inclusion and exclusion of controls. Justification for exclusion can include where the controls are not deemed necessary by the risk assessment and where they are not required by (or are subject to exceptions under) applicable external requirements.

e) 評估人工智慧風險：

- 1) 以風險準則比較風險分析結果 (參見 6.1.1)；
- 2) 訂定已分析風險之風險處理優先序。

組織應保存關於人工智慧風險評鑑流程之文件化資訊。

6.1.3 人工智慧風險處理

考量風險評鑑結果，組織應定義人工智慧風險處理流程，以達成下列事項：

- a) 選擇適切之人工智慧風險處理選項；
- b) 對所選定人工智慧風險處理選項，決定所有必須實作之控制措施，並比較控制措施及附錄 A 中者，並確認未忽略必要之控制措施；

備考 1 附錄 A 提供了參考控制措施，用於實現組織目標並解決與人工智慧系統設計和使用相關的風險。

c) 考量附錄 A 中與人工智慧風險處理選項實施相關的控制措施；

d) 確定是否需要超出附錄 A 的其他控制措施以實施所有風險處理選項；

e) 考慮附錄 B 中有關 b) 和 c) 中決定的控制措施的實作指引；

備考 2 控制目標隱含在所選控制措施中。組織可以從附錄 A 中選擇適當的控制目標和控制措施。附錄 A 所列的控制措施並未盡列，故可能需要額外之控制目標和控制措施。如果需要超出附錄 A 的不同或額外的控制措施，組織可以設計此類控制措施或從現有來源中選取。如適用到其他管理系統，人工智慧風險管理可以整合到其他管理系統中。

f) 產生適用性聲明，其包含必要的控制措施 [參照 b)、c) 和 d)]，並提供控制措施納入及排除適用之理由。排除的理由可包括風險評鑑認為不需要採取控制措施以及適用的外部要求事項不需要採取 (或有例外情況) 之控制措施。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

NOTE 3 The organization can provide documented justifications for excluding any control objectives in general or for specific AI systems, whether those listed in Annex A or established by the organization itself.

g) formulate an AI risk treatment plan.

The organization shall obtain approval from the designated management for the AI risk treatment plan and for acceptance of the residual AI risks. The necessary controls shall be:

- aligned to the objectives in 6.2;
- available as documented information;
- communicated within the organization;
- available to interested parties, as appropriate.

The organization shall retain documented information about the AI risk treatment process.

6.1.4 AI system impact assessment

The organization shall define a process for assessing the potential consequences for individuals or groups of individuals, or both, and societies that can result from the development, provision or use of AI systems.

The AI system impact assessment shall determine the potential consequences an AI system's deployment, intended use and foreseeable misuse has on individuals or groups of individuals, or both, and societies.

The AI system impact assessment shall take into account the specific technical and societal context where the AI system is deployed and applicable jurisdictions.

The result of the AI system impact assessment shall be documented. Where appropriate, the result of the system impact assessment can be made available to relevant interested parties as defined by the organization.

The organization shall consider the results of the AI system impact assessment in the risk assessment (see 6.1.2). A.5 in Table A.1 provides controls for assessing impacts of AI systems.

備考 3 組織可提供文件化之證明以說明排除一般的或針對特定人工智慧系統的任何控制目標，該證明可為附錄 A 所列項目或由組織於事前自行建立。

g) 制訂人工智慧風險處理計畫。

組織應獲得指定管理層對人工智慧風險處理計劃的核准，以及對剩餘人工智慧風險的接受。必要的控制措施應：

- 與 6.2 中的目標保持一致；
- 以文件化資訊提供；
- 在組織內進行傳達；
- 適切時，提供予關注方。

組織應保存關於人工智慧風險處理流程之文件化資訊。

6.1.4 人工智慧系統衝擊評鑑

組織應定義一個流程，用於評鑑人工智慧系統的開發、提供或使用可能對個人或群體，或兩者，以及社會造成的潛在後果。

人工智慧系統衝擊評鑑應決定人工智慧系統的部署、預期用途和可預見的濫用對個人或群體，或兩者，以及社會的潛在後果。

人工智慧系統衝擊評鑑應考量人工智慧系統部署的特定技術和社會全景以及適用的司法管轄區。

人工智慧系統衝擊評鑑的結果應被文件化。於適切時，系統衝擊評鑑的結果可提供給組織所定義的相關關注方。

組織應在風險評鑑中考慮人工智慧系統衝擊評鑑的結果（參見 6.1.2）。表 A.1 中的 A.5 提供了評鑑人工智慧系統衝擊的控制措施。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

NOTE In some contexts (such as safety or privacy critical AI systems), the organization can require that discipline-specific AI system impact assessments (e.g. safety, privacy or security impact) be performed as part of the overall risk management activities of an organization.

6.2 AI objectives and planning to achieve them

The organization shall establish AI objectives at relevant functions and levels.

The AI objectives shall:

- a) be consistent with the AI policy (see 5.2);
- b) be measurable (if practicable);
- c) take into account applicable requirements;
- d) be monitored;
- e) be communicated;
- f) be updated as appropriate;
- g) be available as documented information.

When planning how to achieve its AI objectives, the organization shall determine:

- what will be done;
- what resources will be required;
- who will be responsible;
- when it will be completed;
- how the results will be evaluated.

NOTE A non-exclusive list of AI objectives relating to risk management is provided in Annex C. Control objectives and controls for identifying objectives for responsible development and use of AI systems and measures to achieve them are provided in A.6.1 and A.9.3 in Table A.1. Implementation guidance for these controls is provided in B.6.1 and B.9.3.

6.3 Planning of changes

When the organization determines the need for changes to the AI management system, the changes shall be carried out in a planned manner.

備考 在某些情境 (如與安全或隱私相關的人工智慧系統) 中，組織可要求執行特定面向的人工智慧系統衝擊評鑑 (例如安全性、隱私或資安衝擊) 作為組織整體風險管理活動的一部分。

6.2 人工智慧目標及其達成之規劃

組織應於各相關部門及層級建立人工智慧目標。

人工智慧目標應滿足下列事項：

- a) 與人工智慧政策一致 (參見 5.2)；
- b) 可量測的 (若可行)；
- c) 考量適用之要求事項；
- d) 受監控；
- e) 被傳達；
- f) 於適切時，更新之；
- g) 以文件化資訊提供。

於規劃如何達成人工智慧目標時，組織應決定下列事項：

- 待辦事項；
- 所需資源；
- 負責人員；
- 完成時間；
- 結果之評估方式。

備考 附錄 C 提供了一個與風險管理相關的人工智慧目標的非排他性列表。表 A.1 中的 A.6.1 和 A.9.3 則提供了負責開發和使用人工智慧系統之目標識別及實現的控制目標和控制措施。這些控制措施的實作指引參見 B.6.1 和 B.9.3。

6.3 變更之規劃

當組織決定需要對人工智慧管理系統變更時，應以規劃之方式執行變更。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

7 Support

7.1 Resources

The organization shall determine and provide the resources needed for the establishment, implementation, maintenance and continual improvement of the AI management system.

NOTE Control objectives and controls for AI resources are provided in A.4 in Table A.1. Implementation guidance for these controls is provided in Clause B.4.

7.2 Competence

The organization shall:

- determine the necessary competence of person(s) doing work under its control that affects its AI performance;
 - ensure that these persons are competent on the basis of appropriate education, training or experience;
 - where applicable, take actions to acquire the necessary competence, and evaluate the effectiveness of the actions taken.
- Appropriate documented information shall be available as evidence of competence.

NOTE 1 Implementation guidance for human resources including consideration of necessary expertise is provided in B.4.6.

NOTE 2 Applicable actions can include, for example: the provision of training to, the mentoring of, or the reassignment of currently employed persons; or the hiring or contracting of competent persons.

7.3 Awareness

Persons doing work under the organization's control shall be aware of:

- the AI policy (see 5.2);
- their contribution to the effectiveness of the AI management system, including the benefits of improved AI performance;
- the implications of not conforming with the AI management system requirements.

7 支援

7.1 資源

組織應決定並提供建立、實作、維持及持續改善人工智慧管理系統所需之資源。

備考 A.1 中的 A.4 提供了關於人工智慧資源的控制目標和控制措施。這些控制措施的實作指引參見條款 B.4。

7.2 能力

組織應採取下列措施：

- 決定於組織控制下執行工作，影響其人工智慧績效人員之必要能力。
 - 確保此等人員於適當教育、訓練或經驗之基礎上能勝任；
 - 於適用時，採取行動取得必要能力，並評估所採取行動之有效性。
- 應保存適切之文件化資訊，作為勝任之證據。

備考 1 關於人力資源的實作指引，包括對必要專業知識的考量於 B.4.6 中提供。

備考 2 適用之行動可能包括，例：對現有員工提供訓練、指導或重新指派，或是雇用或委外勝任人員。。

7.3 認知

於組織控制下之工作人員，應認知下列事項：

- 人工智慧政策 (參見 5.2)；
- 其對人工智慧管理系統有效性之貢獻，包括改善之人工智慧績效的益處；
- 未遵循人工智慧管理系統要求事項之可能後果。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

7.4 Communication

The organization shall determine the internal and external communications relevant to the AI management system including:

- what it will communicate;
- when to communicate;
- with whom to communicate;
- how to communicate.

7.5 Documented information

7.5.1 General

The organization's AI management system shall include:

- a) documented information required by this document;
- b) documented information determined by the organization as being necessary for the effectiveness of the AI management system.

NOTE The extent of documented information for an AI management system can differ from one organization to another due to:

- the size of organization and its type of activities, processes, products and services;
- the complexity of processes and their interactions;
- the competence of persons.

7.5.2 Creating and updating documented information

When creating and updating documented information, the organization shall ensure appropriate:

- identification and description (e.g. a title, date, author or reference number);
- format (e.g. language, software version, graphics) and media (e.g. paper, electronic);
- review and approval for suitability and adequacy.

7.4 溝通或傳達

組織應決定，相關於人工智慧管理系統之內外部溝通或傳達的需要，包括下列事項：

- 將溝通或傳達之事項；
- 溝通或傳達時間；
- 溝通或傳達對象；
- 溝通或傳達方式。

7.5 文件化資訊

7.5.1 一般要求

組織之人工智慧管理系統應包括下列內容：

- a) 本文件要求之文件化資訊；
- b) 由組織決定對人工智慧管理系統有效性，必要之文件化資訊。

備考 各組織之人工智慧管理系統文件化資訊內容，可能因下列因素而異：

- 組織規模，以及其活動之形式、流程、產品及服務；
- 各流程及其互動之複雜度；
- 人員之能力。

7.5.2 制訂及更新文件化資訊

於制定及更新文件化資訊時，組織應確保適切之下列項目：

- 識別和描述（例如：標題、日期、作者或參引號碼）；
- 格式（例如：語言、軟體版本、圖形）和媒介（例如：紙本、電子）；
- 合宜性及適切性之審查及核可。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

7.5.3 Control of documented information

Documented information required by the AI management system and by this document shall be controlled to ensure:

- a) it is available and suitable for use, where and when it is needed;
- b) it is adequately protected (e.g. from loss of confidentiality, improper use or loss of integrity).

For the control of documented information, the organization shall address the following activities, as applicable:

- distribution, access, retrieval and use;
- storage and preservation, including preservation of legibility;
- control of changes (e.g. version control);
- retention and disposition.

Documented information of external origin determined by the organization to be necessary for the planning and operation of the AI management system shall be identified as appropriate and controlled.

NOTE Access can imply a decision regarding the permission to view the documented information only, or the permission and authority to view and change the documented information.

8 Operation

8.1 Operational planning and control

The organization shall plan, implement and control the processes needed to meet requirements, and to implement the actions determined in Clause 6, by:

- establishing criteria for the processes;
- implementing control of the processes in accordance with the criteria.

The organization shall implement the controls determined according to 6.1.3 that are related to the operation of the AI management system (e.g. AI system development and usage life cycle related controls). The effectiveness of these controls shall be monitored and corrective actions shall be considered if the intended results are not achieved. Annex A lists reference controls and Annex B provides implementation guidance for them.

7.5.3 文件化資訊之控制

應控制人工智慧管理系統及本文件要求之文件化資訊，以確保下列事項：

- a) 其於需要處及需要時為可用及適用。
- b) 其受適切保護 (如：防止漏失機密性、不當使用或喪失完整性)。

為控制文件化資訊，於適當時，組織應闡明下列活動：

- 派送、存取、檢索及使用；
- 儲存和保存，包括可讀性之保存；
- 變更控制 (如：版本控制)；
- 留存及屆期處置。

於適切時，應識別及控制由組織所決定對人工智慧管理系統之規劃及運作為必要之外部來源的文件化資訊。

備考 存取可能意味關於文件化資訊僅可檢視之許可，或檢視及變更文件化資訊之許可及權限等之決策。

8 運作

8.1 運作之規劃及控制

組織應規劃、實作及控制達成要求事項所需之流程，並實作第 6 節中所決定之行動，以：

- 為流程建立準則；
- 依準則實作流程之控制措施。

組織應實施根據 6.1.3 決定與人工智慧管理系統運作相關的控制措施 (例如與人工智慧系統開發和使用生命週期相關的控制)。

應監督這些控制措施之有效性，如未達預期結果，應考慮採取矯正措施。附錄 A 列出了參考控制措施，附錄 B 則提供該措施的實作指引。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Documented information shall be available to the extent necessary to have confidence that the processes have been carried out as planned.

The organization shall control planned changes and review the consequences of unintended changes, taking action to mitigate any adverse effects, as necessary.

The organization shall ensure that externally provided processes, products or services that are relevant to the AI management system are controlled.

8.2 AI risk assessment

The organization shall perform AI risk assessments in accordance with 6.1.2 at planned intervals or when significant changes are proposed or occur.

The organization shall retain documented information of the results of all AI risk assessments.

8.3 AI risk treatment

The organization shall implement the AI risk treatment plan according to 6.1.3 and verify its effectiveness. When risk assessments identify new risks that require treatment, a risk treatment process in accordance with 6.1.3 shall be performed for these risks.

When risk treatment options as defined by the risk treatment plan are not effective, these treatment options shall be reviewed and revalidated following the risk treatment process according to 6.1.3 and the risk treatment plan shall be updated.

The organization shall retain documented information of the results of all AI risk treatments.

8.4 AI system impact assessment

The organization shall perform AI system impact assessments according to 6.1.4 at planned intervals or when significant changes are proposed to occur.

The organization shall retain documented information of the results of all AI system impact assessments.

應提供文件化資訊，其程度必須具有足以達成其流程已依規劃執行之信心。

組織應控制所規劃之變更，並審查非預期變更之後果，必要時採取行動以減輕任何負面效果。

組織應確保與人工智慧管理系統相關的外部提供之流程、產品或服務受到控制。

8.2 人工智慧風險評鑑

組織應依規劃之期間或當提議或發生重大變更時，依據 6.1.2 執行人工智慧風險評鑑。

組織應保存所有人工智慧風險評鑑結果的文件化資訊。

8.3 人工智慧風險處理

組織應根據 6.1.3 實施人工智慧風險處理計劃，並驗證其有效性。

當風險評鑑識別出需要處理的新風險時，應根據 6.1.3 對這些風險進行風險處理。

當風險處理計劃中定義的風險處理選項無效時，應審查並重新驗證這些處理選項，並應根據 6.1.3 的風險處理流程更新風險處理計劃。

組織應保存所有人工智慧風險處理結果之文件化資訊。

8.4 人工智慧系統衝擊評鑑

組織應依規劃之期間或發生重大變更時，依據 6.1.4 執行人工智慧系統衝擊評鑑。

組織應保存所有人工智慧系統衝擊評鑑結果的文件化資訊。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

9 Performance evaluation

9.1 Monitoring, measurement, analysis and evaluation

The organization shall determine:

- what needs to be monitored and measured;
- the methods for monitoring, measurement, analysis and evaluation, as applicable, to ensure valid results;
- when the monitoring and measuring shall be performed;
- when the results from monitoring and measurement shall be analysed and evaluated.

Documented information shall be available as evidence of the results.

The organization shall evaluate the performance and the effectiveness of the AI management system.

9.2 Internal audit

9.2.1 General

The organization shall conduct internal audits at planned intervals to provide information on whether the AI management system:

- a) conforms to:
 - 1) the organization's own requirements for its AI management system;
 - 2) the requirements of this document;
- b) is effectively implemented and maintained.

9.2.2 Internal audit programme

The organization shall plan, establish, implement and maintain (an) audit programme(s), including the frequency, methods, responsibilities, planning requirements and reporting.

When establishing the internal audit programme(s), the organization shall consider the importance of the processes concerned and the results of previous audits.

The organization shall:

- a) define the audit objectives, criteria and scope for each audit;

9 績效評估

9.1 監督、量測、分析及評估

組織應決定：

- 需要監督及量測之事項；
- 監督、量測、分析及評估之適用方法，以確保有效的結果；
- 應執行監督及量測之時間；
- 監督及量測結果應分析及評估之時間。

應具備文件化資訊，作為結果之證據。

組織應評估人工智慧管理系統之績效及有效性。

9.2 內部稽核

9.2.1 一般要求

組織應依規劃之期間施行內部稽核，以提供人工智慧管理系統之下列資訊：

- a) 是否符合下列事項：
 - 1) 組織本身對其人工智慧管理系統之要求事項；
 - 2) 本文件之要求事項；
- b) 是否有效實作及維持。

9.2.2 內部稽核方案

組織應規劃、建立、實作及維持稽核方案，包括頻率、方法、責任、規劃要求事項與報告。

建立內部稽核方案時，組織應將所關注之重要流程及先前稽核之結果納入考量。

組織應：

- a) 定義各稽核之稽核目標、準則及範圍；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

b) select auditors and conduct audits to ensure objectivity and the impartiality of the audit process;

c) ensure that the results of audits are reported to relevant managers.

Documented information shall be available as evidence of the implementation of the audit programme(s) and the audit results.

9.3 Management review

9.3.1 General

Top management shall review the organization's AI management system, at planned intervals, to ensure its continuing suitability, adequacy and effectiveness.

9.3.2 Management review inputs

The management review shall include:

- a) the status of actions from previous management reviews;
- b) changes in external and internal issues that are relevant to the AI management system;
- c) changes in needs and expectations of interested parties that are relevant to the AI management system;
- d) information on the AI management system performance, including trends in:
 - 1) nonconformities and corrective actions;
 - 2) monitoring and measurement results;
 - 3) audit results;
- e) opportunities for continual improvement.

9.3.3 Management review results

The results of the management review shall include decisions related to continual improvement opportunities and any need for changes to the AI management system.

Documented information shall be available as evidence of the results of management reviews.

b) 選擇稽核員及施行稽核，以確保稽核流程之客觀性及公平性；

c) 確保稽核之結果對相關管理階層報告。

應具備文件化資訊，作為稽核方案實作及稽核結果之證據。

9.3 管理審查

9.3.1 一般要求

最高管理階層應於規劃之期間，審查組織之人工智慧管理系統，以確保其持續的適切性、合宜性及有效性。

9.3.2 管理審查輸入

管理審查應包括對下列事項之考量：

- a) 過往管理審查之決議的處理狀態；
- b) 與人工智慧管理系統有關之外部及內部議題的變更；
- c) 與人工智慧管理系統相關關注方之需要及期望的變更；
- d) 人工智慧管理系統績效之資訊，包括下列之趨勢：
 - 1) 不符合事項及矯正措施；
 - 2) 監督及量測結果；
 - 3) 稽核結果；
- e) 持續改善之機會。

9.3.3 管理審查結果

管理審查之結果應包括與持續改善機會相關之決策以及對任何對人工智慧管理系統變更之需要。

應具備文件化資訊，以作為管理審查結果之證據。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

10 Improvement

10.1 Continual improvement

The organization shall continually improve the suitability, adequacy and effectiveness of the AI management system.

10.2 Nonconformity and corrective action

When a nonconformity occurs, the organization shall:

a) react to the nonconformity and as applicable:

- 1) take action to control and correct it;
- 2) deal with the consequences;

b) evaluate the need for action to eliminate the cause(s) of the nonconformity, so that it does not recur or occur elsewhere, by:

- 1) reviewing the nonconformity;
- 2) determining the causes of the nonconformity;
- 3) determining if similar nonconformities exist or can potentially occur;

c) implement any action needed;

d) review the effectiveness of any corrective action taken;

e) make changes to the AI management system, if necessary.

Corrective actions shall be appropriate to the effects of the nonconformities encountered.

Documented information shall be available as evidence of:

- the nature of the nonconformities and any subsequent actions taken;
- the results of any corrective action.

10 改善

10.1 持續改善

組織應持續改善人工智慧管理系統的合宜性、適切性及有效性。

10.2 不符合事項及矯正措施

不符合事項發生時，組織應有下列作為：

a) 對不符合事項反應，並於適用時，採取下列作為：

- 1) 採取行動以控制並矯正之；
- 2) 處理其後果；

b) 藉由下列作為，評估對消除不符合項目之原因的行動之需要，使其不再發生且不於他處發生：

- 1) 審查不符合事項；
- 2) 決定不符合事項之原因；
- 3) 決定是否有類似之不符合項目存在，或可能發生；

c) 實作所有所需行動；

d) 審查所有所採取矯正措施之有效性；

e) 必要時，對人工智慧管理系統進行變更。

矯正措施應切合所遇到不符合事項之影響。

應具備文件化資訊，以作為下列事項之證據：

- 不符合事項之性質及後續採取的所有行動；
- 所有矯正措施之結果。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Annex A
(normative)

Reference control objectives and controls

A.1 General

The controls detailed in Table A.1 provide the organization with a reference for meeting organizational objectives and addressing risks related to the design and operation of AI systems. Not all the control objectives and controls listed in Table A.1 are required to be used, and the organization can design and implement their own controls (see 6.1.3).

Annex B provides implementation guidance for all the controls listed in Table A.1.

Table A.1 — Control objectives and controls

A.2 Policies related to AI		
Objective: To provide management direction and support for AI systems according to business requirements.		
	Topic	Control
A.2.2	AI policy	The organization shall document a policy for the development or use of AI systems.
A.2.3	Alignment with other organizational policies	The organization shall determine where other policies can be affected by or apply to, the organization's objectives with respect to AI systems.

附錄A
(規範性)

參考控制目標與控制措施

A.1 通則

表 A.1 中所詳述之各項控制措施，為組織提供一個以達成組織目標並應對與人工智慧系統設計和運作相關風險之參考。並非表 A.1 中所列出之控制目標與控制措施皆需納入使用，組織內部可設計並實施自己的控制措施（參見 6.1.3）。

附錄 B 提供了表 A.1 中所有控制措施的實作指引。

表 A.1 - 控制目標與控制措施

A.2 人工智慧相關政策		
目標：根據業務需求為人工智慧系統提供管理方向與支持。		
	主題	控制措施
A.2.2	人工智慧政策	組織應制定並文件化一份關於人工智慧系統開發或使用的政策。
A.2.3	與組織其他政策之一致性	組織應決定其他政策可能受到影響或適用於組織關於人工智慧系統的目標。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

A.2.4	Review of the AI policy	The AI policy shall be reviewed at planned intervals or additionally as needed to ensure its continuing suitability, adequacy and effectiveness.
-------	-------------------------	--

A.2.4	人工智慧政策之審查	應於所規劃之期間或根據需要審查人工智慧政策，以確保其持續之合宜性、適切性及有效性。
-------	-----------	---

A.3 Internal organization

Objective: To establish accountability within the organization to uphold its responsible approach for the implementation, operation and management of AI systems.

	Topic	Control
A.3.2	AI roles and responsibilities	Roles and responsibilities for AI shall be defined and allocated according to the needs of the organization.
A.3.3	Reporting of concerns	The organization shall define and put in place a process to report concerns about the organization's role with respect to an AI system throughout its life cycle.

A.3 內部組織

目標：在組織內建立當責機制，以維持其對人工智慧系統實施、運作和管理的負責任方法。

	主題	控制措施
A.3.2	人工智慧角色與責任	應依據組織的需要，定義及配置人工智慧角色與責任。
A.3.3	關注事項的通報	組織應定義並實施一個流程，以通報組織在人工智慧系統整個生命週期中的角色的關注事項。

A.4 Resources for AI systems

Objective: To ensure that the organization accounts for the resources (including AI system components and assets) of the AI system in order to fully understand and address risks and impacts.

	Topic	Control
A.4.2	Resource documentation	The organization shall identify and document relevant resources required for the activities at given AI system life cycle stages and other AI-related activities relevant for the organization.

A.4 人工智慧系統資源

目標：確認組織所使用之人工智慧系統資源（包括人工智慧系統組件和資產），以利充分理解及應對其風險和衝擊。

	主題	控制措施
A.4.2	資源文件化	組織應識別並文件化在特定人工智慧系統生命週期階段和其他與組織相關的人工智慧活動中所需的相關資源。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

A.4.3	Data resources	As part of resource identification, the organization shall document information about the data resources utilized for the AI system.
A.4.4	Tooling resources	As part of resource identification, the organization shall document information about the tooling resources utilized for the AI system.
A.4.5	System and computing resources	As part of resource identification, the organization shall document information about the system and computing resources utilized for the AI system.
A.4.6	Human resources	As part of resource identification, the organization shall document information about the human resources and their competences utilized for the development, deployment, operation, change management, maintenance, transfer and decommissioning, as well as verification and integration of the AI system.

A.4.3	資料資源	作為資源識別的一部分，組織應文件化有關人工智慧系統使用的資料資源之資訊。
A.4.4	工具資源	作為資源識別的一部分，組織應文件化有關人工智慧系統使用的工具資源之資訊。
A.4.5	系統與運算資源	作為資源識別的一部分，組織應文件化有關人工智慧系統使用的系統和運算資源之資訊。
A.4.6	人力資源	作為資源識別的一部分，組織應文件化有關在人力資源及其能力方面之資源，包括在人工智慧系統的開發、部署、運作、變更管理、維護、轉移和停止使用，以及驗證和整合中的使用情況。

A.5 Assessing impacts of AI systems

Objective: To assess AI system impacts to individuals or groups of individuals, or both, and societies affected by the AI system throughout its life cycle.

	Topic	Control
A.5.2	AI system impact assessment process	The organization shall establish a process to assess the potential consequences for individuals or groups of individuals, or both, and societies that can result from the AI system throughout its life cycle.

A.5 人工智慧系統之評鑑衝擊

目標：評鑑人工智慧系統在其生命週期中對個人或群體，或二者，以及社會的影響。

	主題	控制措施
A.5.2	人工智慧系統衝擊評鑑流程	組織應建立一個流程，評估人工智慧系統在其生命週期中可能對個人或群體，或二者，以及社會產生的潛在後果。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

A.5.3	Documentation of AI system impact assessments	The organization shall document the results of AI system impact assessments and retain results for a defined period.
A.5.4	Assessing AI system impact on individuals or groups of individuals	The organization shall assess and document the potential impacts of AI systems to individuals or groups of individuals throughout the system's life cycle.
A.5.5	Assessing societal impacts of AI systems	The organization shall assess and document the potential societal impacts of their AI systems throughout their life cycle.

A.6 AI system life cycle		
A.6.1 Management guidance for AI system development		
Objective: To ensure that the organization identifies and documents objectives and implements processes for the responsible design and development of AI systems.		
	Topic	Control
A.6.1.2	Objectives for responsible development of AI system	The organization shall identify and document objectives to guide the responsible development AI systems, and take those objectives into account and integrate measures to achieve them in the development life cycle.
A.6.1.3	Processes for responsible AI system design and development	The organization shall define and document the specific processes for the responsible design and development of the AI system.

A.5.3	人工智慧系統衝擊評鑑之文件化	組織應文件化人工智慧系統衝擊評鑑的結果，並於規定之期間內留存。
A.5.4	人工智慧系統對個人或群體的衝擊評鑑	組織應評鑑並文件化人工智慧系統在其生命週期中對個人或群體的潛在衝擊。
A.5.5	人工智慧系統對社會的衝擊評鑑	組織應評鑑並文件化人工智慧系統在其生命週期中對社會的潛在衝擊。

A.6 人工智慧系統生命週期		
A.6.1 人工智慧系統開發的管理指導		
目標：確保組織識別並文件化目標，並實施負責任的人工智慧系統設計和開發流程。		
	主題	控制措施
A.6.1.2	負責任人工智慧系統開發之目標	組織應識別並文件化目標，以引導負責任人工智慧系統的開發，並參照這些目標與整合相關措施以在開發生命週期中達到這些目標。
A.6.1.3	負責任的人工智慧系統設計和開發流程	組織應定義並文件化負責任人工智慧系統設計和開發的具體流程。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

A.6.2 AI system life cycle		
Objective: To define the criteria and requirements for each stage of the AI system life cycle.		
	Topic	Control
A.6.2.2	AI system requirements and specification	The organization shall specify and document requirements for new AI systems or material enhancements to existing systems.
A.6.2.3	Documentation of AI system design and development	The organization shall document the AI system design and development based on organizational objectives, documented requirements and specification criteria.
A.6.2.4	AI system verification and validation	The organization shall define and document verification and validation measures for the AI system and specify criteria for their use.
A.6.2.5	AI system deployment	The organization shall document a deployment plan and ensure that appropriate requirements are met prior to deployment.
A.6.2.6	AI system operation and monitoring	The organization shall define and document the necessary elements for the ongoing operation of the AI system. At the minimum, this should include system and performance monitoring, repairs, updates and support.

A.6.2 人工智慧系統生命週期		
目標：為人工智慧系統生命週期的每個階段定義準則和要求。		
	主題	控制措施
A.6.2.2	人工智慧系統要求與規範	組織應為新人工智慧系統或對既有系統之重大增強進行註明並文件化需求。
A.6.2.3	人工智慧系統設計與開發的文件化	組織應根據組織目標、文件化的要求和規範準則，文件化人工智慧系統的設計與開發流程。
A.6.2.4	人工智慧系統的驗證與確認	組織應為人工智慧系統定義並文件化驗證與確認措施，並註明其使用標準。
A.6.2.5	人工智慧系統部署	組織應文件化部署計劃，並確保在部署前滿足相關要求。
A.6.2.6	人工智慧系統的運作與監控	組織應定義並文件化人工智慧系統持續運作所需的要素，至少宜包括系統和性能監控、維修、更新和支援。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

A.6.2.7	AI system technical documentation	The organization shall determine what AI system technical documentation is needed for each relevant category of interested parties, such as users, partners, supervisory authorities, and provide the technical documentation to them in the appropriate form.
A.6.2.8	AI system recording of event log	The organization shall determine at which phases of the AI system life cycle, record keeping of event logs should be enabled, but at the minimum when the AI system is in use.

A.6.2.7	人工智慧系統技術文件化	組織應決定每個相關關注方(如使用者、合作夥伴、監管機構)所需的人工智慧系統技術文件化，並以適當形式向他們提供技術文件化。
A.6.2.8	人工智慧系統之事件日誌紀錄	組織應決定在人工智慧系統生命週期的哪些階段宜啟用事件日誌紀錄，但至少在人工智慧系統使用時啟用。

A.7 Data for AI systems		
Objective: To ensure that the organization understands the role and impacts of data in AI systems in the application and development, provision or use of AI systems throughout their life cycles.		
	Topic	Control
A.7.2	Data for development and enhancement of AI system	The organization shall define, document and implement data management processes related to the development of AI systems.
A.7.3	Acquisition of data	The organization shall determine and document details about the acquisition and selection of the data used in AI systems.
A.7.4	Quality of data for AI systems	The organization shall define and document requirements for data quality and ensure that data used to develop and operate the AI system meet those requirements.

A.7 人工智慧系統之資料		
目標：確保組織了解資料在人工智慧系統中的角色及其在應用、開發、提供或使用人工智慧系統的流程中對其生命週期的影響。		
	主題	控制措施
A.7.2	用於人工智慧系統開發與增強型之資料	組織應定義、文件化並實作與人工智慧系統開發相關的資料管理流程。
A.7.3	資料之獲取	組織應決定並文件化有關人工智慧系統中使用之資料獲取與選擇的詳細資訊。
A.7.4	人工智慧系統資料品質	組織應定義並文件化資料品質之要求，並確保用於開發和運行人工智慧系統的資料符合這些要求。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

A.7.5	Data provenance	The organization shall define and document a process for recording the provenance of data used in its AI systems over the life cycles of the data and the AI system.
A.7.6	Data preparation	The organization shall define and document its criteria for selecting data preparations and the data preparation methods to be used.

A.7.5	資料來歷	組織應對人工智慧系統中的資料，在其資料和人工智慧系統之生命週期中，定義並文件化資料來歷之流程。
A.7.6	資料準備	組織應定義並文件化其選擇之資料準備和資料準備方法的準則。

A.8 Information for interested parties of AI systems		
Objective: To ensure that relevant interested parties have the necessary information to understand and assess the risks and their impacts (both positive and negative).		
	Topic	Control
A.8.2	System documentation and information for users	The organization shall determine and provide the necessary information to users of the AI system.
A.8.3	External reporting	The organization shall provide capabilities for interested parties to report adverse impacts of the AI system.
A.8.4	Communication of incidents	The organization shall determine and document a plan for communicating incidents to users of the AI system.
A.8.5	Information for interested parties	The organization shall determine and document their obligations to reporting information about the AI system to interested parties.

A.8 人工智慧系統之關注方資訊		
目標 確保相關關注方擁有必要之資訊，以瞭解與評鑑風險及其衝擊 (包括正面和負面)。		
	主題	控制措施
A.8.2	系統文件化與使用者資訊	組織應決定並向人工智慧系統的使用者提供必要之資訊。
A.8.3	外部通報	組織應提供讓關注方能夠通報人工智慧系統不良衝擊之機制。
A.8.4	事故溝通或傳達	組織應決定並文件化向人工智慧系統使用者溝通或傳達事故的規劃。
A.8.5	關注方資訊	組織應決定並文件化向關注方報告人工智慧系統資訊的義務。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

A.9 Use of AI systems		
Objective: To ensure that the organization uses AI systems responsibly and per organizational policies.		
	Topic	Control
A.9.2	Processes for responsible use of AI systems	The organization shall define and document the processes for the responsible use of AI systems.
A.9.3	Objectives for responsible use of AI system	The organization shall identify and document objectives to guide the responsible use of AI systems.
A.9.4	Intended use of the AI system	The organization shall ensure that the AI system is used according to the intended uses of the AI system and its accompanying documentation.

A.9 人工智慧系統之使用		
目標：確保組織遵循組織政策負責任地使用人工智慧系統。		
	主題	控制措施
A.9.2	負責任使用人工智慧系統之流程	組織應定義並文件化負責任使用人工智慧系統的流程。
A.9.3	負責任使用人工智慧系統之目標	組織應識別並文件化目標，以指導人工智慧系統的負責任使用。
A.9.4	人工智慧系統之預期用途	組織應確保人工智慧系統根據其預期用途和隨附之文件化進行使用。

A.10 Third-party and customer relationships		
Objective: To ensure that the organization understands its responsibilities and remains accountable, and risks are appropriately apportioned when third parties are involved at any stage of the AI system life cycle.		
	Topic	Control
A.10.2	Allocating responsibilities	The organization shall ensure that responsibilities within their AI system life cycle are allocated between the organization, its partners, suppliers, customers and third parties.

A.10 第三方與客戶之關係		
目標：確保組織瞭解其責任並承擔責任，當第三方參與人工智慧系統生命週期的任何階段時，適當地分配風險。		
	主題	控制措施
A.10.2	責任之分配	組織應確保在其人工智慧系統生命週期內的責任在組織、其合作夥伴、供應商、客戶和第三方之間進行分配。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

A.10.3	Suppliers	The organization shall establish a process to ensure that its usage of services, products or materials provided by suppliers aligns with the organization's approach to the responsible development and use of AI systems.	A.10.3	供應商	組織應建立一個流程，以確保其使用供應商提供的服務、產品或材料符合組織對人工智慧系統負責任開發和使用的方法。
A.10.4	Customers	The organization shall ensure that its responsible approach to the development and use of AI systems considers their customer expectations and needs.	A.10.4	客戶	組織應確保其對人工智慧系統開發和使用的負責任方法考量到客戶的期望和需求。

訓練專用 禁止翻印

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Annex B (normative)

Implementation guidance for AI controls

B.1 General

The implementation guidance documented in this annex relates to the controls listed in Table A.1. It provides information to support the implementation of the controls listed in Table A.1 and to meet the control objective, but organizations do not have to document or justify inclusion or exclusion of implementation guidance in the statement of applicability (see 6.1.3).

The implementation guidance is not always suitable or sufficient in all situations and does not always fulfil the organization's specific control requirements. The organization can extend or modify the implementation guidance or define their own implementation of a control according to their specific requirements and risk treatment needs.

This annex is to be used as guidance for determining and implementing controls for AI risk treatment in the AI management system defined in this document. Additional organizational and technical controls other than those included in this annex can be determined (see AI system management risk treatment in 6.1.3). This annex can be regarded as a starting point for developing organization-specific implementation of controls.

B.2 Policies related to AI

B.2.1 Objective

To provide management direction and support for AI systems according to business requirements.

B.2.2 AI policy

Control

The organization should document a policy for the development or use of AI systems.

Implementation guidance

The AI policy should be informed by:

附錄B (規範性)

人工智慧控制措施之實作指引

B.1 一般要求

本附錄中文件化的實作指引與表 A.1 中列出的控制措施相關，提供了支持表 A.1 中控制措施實施用以達成控制目標之資訊，但組織不需於適用性聲明書中記錄或證明實作指引的納入或排除（參見 6.1.3）。

實作指引並非適用於所有情況，也不全符合組織的特定控制要求。組織可以根據其特定需求和風險處理需要，擴展或修改實作指引，或自行定義控制措施的實施方式。

本附錄作為於本文件中所定義用於決定與實作人工智慧管理系統中的人工智慧風險處理控制措施之指引。除了本附錄中包含的控制措施外，其他組織性和技術性控制措施（參見 6.1.3 中的人工智慧系統管理風險處理）則可另定。本附錄可視為開發組織特定控制措施實施之起始。

B.2 人工智慧相關政策

B.2.1 目標

根據業務需求為人工智慧系統提供管理方向與支持。

B.2.2 人工智慧政策

控制措施

組織宜制定並文件化一份關於人工智慧系統開發或使用的政策。

實作指引

人工智慧政策宜考慮以下因素：

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

- business strategy;
- organizational values and culture and the amount of risk the organization is willing to pursue or retain;
- the level of risk posed by the AI systems;
- legal requirements, including contracts;
- the risk environment of the organization;
- impact to relevant interested parties (see 6.1.4).

The AI policy should include (in addition to requirements in 5.2):

- principles that guide all activities of the organization related to AI;
- processes for handling deviations and exceptions to policy.

The AI policy should consider topic-specific aspects where necessary to provide additional guidance or provide cross-references to other policies dealing with these aspects. Examples of such topics include:

- AI resources and assets;
- AI system impact assessments (see 6.1.4);
- AI system development.

Relevant policies should guide the development, purchase, operation and use of AI systems.

B.2.3 Alignment with other organizational policies

Control

The organization should determine where other policies can be affected by or apply to, the organization's objectives with respect to AI systems.

Implementation guidance

Many domains intersect with AI, including quality, security, safety and privacy. The organization should consider a thorough analysis to determine whether and where current policies can necessarily intersect and either update those policies if updates are required or include provisions in the AI policy.

- 營運策略；
- 組織的價值觀和文化，及組織願意承擔或保留的風險程度；
- 人工智慧系統所帶來的風險等級；
- 法律要求，包括合約；
- 組織的風險環境；
- 對相關關注方的影響（參見 6.1.4）。

人工智慧政策宜包括（除 5.2 中的要求外）：

- 指導組織與人工智慧相關所有活動之原則；
- 處理政策偏離和例外情況的流程。

人工智慧政策宜在必要時考慮特定主題的相關面向，以提供額外的指導或交互參考其他涵蓋這些面向的政策。此類主題的範例包括：

- 人工智慧資源與資產；
- 人工智慧系統衝擊評鑑（參見 6.1.4）；
- 人工智慧系統開發。

相關政策宜指導人工智慧系統的開發、採購、運作與使用。

B.2.3 與組織其他政策之一致性

控制措施

組織宜決定其他政策可能受到影響或適用於組織關於人工智慧系統的目標。

實作指引

許多領域與人工智慧相互關連，包括品質、資安、安全、隱私等。組織宜考量進行全面分析，以確定當前政策是否以及在哪些方面需要與人工智慧政策關聯，並在需要時更新這些政策或在人工智慧政策中加入相關條款。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Other information

The policies that the governing body sets on behalf of the organization should inform the AI policy. ISO/IEC 38507 provides guidance for members of the governing body of an organization to enable and govern the AI system throughout its life cycle.

B.2.4 Review of the AI policy

Control

The AI policy should be reviewed at planned intervals or additionally as needed to ensure its continuing suitability, adequacy and effectiveness.

Implementation guidance

A role approved by management should be responsible for the development, review and evaluation of the AI policy, or the components within. The review should include assessing opportunities for improvement of the organization's policies and approach to managing AI systems in response to changes to the organizational environment, business circumstances, legal conditions or technical environment.

The review of AI policy should take the results of management reviews into account.

B.3 Internal organization

B.3.1 Objective

To establish accountability within the organization to uphold its responsible approach for the implementation, operation and management of AI systems.

B.3.2 AI roles and responsibilities

Control

Roles and responsibilities for AI should be defined and allocated according to the needs of the organization.

Implementation guidance

Defining roles and responsibilities is critical for ensuring accountability throughout the organization for its role with respect to the AI system throughout its life cycle. The organization should consider AI policies, AI objectives and identified risks when assigning roles and responsibilities, in order to ensure that all relevant areas are covered. The organization can prioritize how the

其他資訊

管理機構代表組織制定的政策宜為人工智慧政策提供資訊。ISO/IEC 38507 為組織管理機構成員提供指導，以在人工智慧系統的整個生命週期中啟用和管理人工智慧系統。

B.2.4 人工智慧政策之審查

控制措施

宜於所規劃之期間或根據需要審查人工智慧政策，以確保其持續之合宜性、適切性及有效性。

實作指引

經管理階層批准的角色宜負責人工智慧政策或其組成部分的制定、審查和評估。審查宜包括評估改善組織管理人工智慧系統的政策和方法的機會，以應對組織環境、業務環境、法律條件或技術環境的變化。

人工智慧政策的審查宜考慮管理審查的結果。

B.3 內部組織

B.3.1 目標

在組織內建立當責機制，以維持其對人工智慧系統實施、運作和管理的負責任方法。

B.3.2 人工智慧角色與責任

控制措施

宜根據組織的需要，定義及配置人工智慧角色與責任。

實作指引

定義角色與職責對確保組織在人工智慧系統整個生命週期中對其角色的當責性至關重要。組織宜在分配角色與責任時考量人工智慧政策、人工智慧目標和已識別的風險，以確保涵蓋所有相關領域。組織可以根據優先級分配角色與責任。可能需要定義角色與責任的領域包括：

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

roles and responsibilities are assigned. Examples of areas that can require defined roles and responsibilities can include:

- risk management;
 - AI system impact assessments;
 - asset and resource management;
 - security;
 - safety;
 - privacy;
 - development;
 - performance;
 - human oversight;
 - supplier relationships;
 - demonstrate its ability to consistently fulfil legal requirements;
 - data quality management (during the whole life cycle).
- 風險管理；
 - 人工智慧系統衝擊評鑑；
 - 資產和資源管理；
 - 資訊安全；
 - 安全性；
 - 隱私性；
 - 開發；
 - 績效表現；
 - 人為監管；
 - 供應商關係；
 - 展現其持續遵守法律要求的能力；
 - 資料品質管理（於整個生命週期中）。

Responsibilities of the various roles should be defined to the level appropriate for the individuals to perform their duties.

宜將各種角色的責任定義為適合個人履行其職責的等級。

B.3.3 Reporting of concerns

B.3.3 關注事項的通報

Control

控制措施

The organization should define and put in place a process to report concerns about the organization's role with respect to an AI system throughout its life cycle.

組織宜定義並實施一個流程，以通報組織在人工智慧系統整個生命週期中的角色的關注事項。

Implementation guidance

實作指引

The reporting mechanism should fulfil the following functions:

通報機制宜具備以下功能：

- a) options for confidentiality or anonymity or both;
 - b) available and promoted to employed and contracted persons;
 - c) staffed with qualified persons;
 - d) stipulates appropriate investigation and resolution powers for the persons referred to in c);
- a) 提供保密或匿名選項，或二者兼具；
 - b) 提供並推廣給僱用和契約人員；
 - c) 由具備資格的人員負責；
 - d) 為 c) 中提及的人員規定適當的調查和解決權限；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

e) provides for mechanisms to report and to escalate to management in a timely manner;

f) provides for effective protection from reprisals for both the persons concerned with reporting and investigation (e.g. by allowing reports to be made anonymously and confidentially);

g) provides reports according to 4.4 and, if appropriate, e); while maintaining confidentiality and anonymity in a), and respecting general business confidentiality considerations;

h) provides response mechanisms within an appropriate time frame.

NOTE The organization can utilize existing reporting mechanisms as part of this process.

Other information

In addition to the implementation guidance provided in this clause, the organization should further consider ISO 37002.

B.4 Resources for AI systems

B.4.1 Objective

To ensure that the organization accounts for the resources (including AI system components and assets) of the AI system in order to fully understand and address risks and impacts.

B.4.2 Resource documentation

Control

The organization should identify and document relevant resources required for the activities at given AI system life cycle stages and other AI-related activities relevant for the organization.

Implementation guidance

Documentation of resources of the AI system is critical for understanding risks, as well as potential AI system impacts (both positive and negative) to individuals or groups of individuals, or both, and societies. The documentation of such resources (which can utilize, for instance, data flow diagrams or system architecture diagrams) can inform the AI system impact assessments (see B.5).

Resources can include, but are not limited to:

— AI system components;

e) 提供機制，允許及時向管理層報告和升級；

f) 提供有效保護，防止對報告和調查的相關人員進行報復（例如，允許匿名和保密報告）；

g) 提供根據 4.4 或，適切時，e) 的通報，同時保持 a) 中的保密性和匿名性，並尊重一般業務機密考量；

h) 提供在適當時間範圍內的回應機制。

備考 組織可以將現有的通報機制作為此流程的一部分。

其他資訊

除了本條款提供的實作指引外，組織宜進一步考量 ISO 37002。

B.4 人工智慧系統資源

B.4.1 目標

確認組織所使用之人工智慧系統資源（包括人工智慧系統組件和資產），以利充分理解及應對其風險和衝擊。

B.4.2 資源文件化

控制措施

組織宜識別並文件化在特定人工智慧系統生命週期階段和其他與組織相關的人工智慧活動中所需的相關資源。

實作指引

人工智慧系統資源之文件化對於了解風險以及人工智慧系統對個人或群體，以及對社會的潛在衝擊（包括正面和負面）至關重要。此類資源的文件化（例如使用資料流程圖或系統架構圖）可為人工智慧系統衝擊評鑑提供資訊（參見 B.5）。

資源可以包括但不限於：

— 人工智慧系統組件；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

— data resources, i.e. data used at any stage in the AI system life cycle;

— tooling resources (e.g. AI algorithms, models or tools);

— system and computing resources (e.g. hardware to develop and run AI models, storage for data and tooling resources);

— human resources, i.e. people with the necessary expertise (e.g. for the development, sales, training, operation and maintenance of the AI system) in relation to the organization's role throughout the AI system life cycle.

Resources can be provided by the organization itself, by its customers or by third parties.

Other information

Documentation of resources can also help to determine if resources are available and, if they are not available, the organization should revise the design specification of the AI system or its deployment requirements.

B.4.3 Data resources

Control

As part of resource identification, the organization should document information about the data resources utilized for the AI system.

Implementation guidance

Documentation on data should include, but is not limited to, the following topics:

— the provenance of the data;

— the date that the data were last updated or modified (e.g. date tag in metadata);

— for machine learning, the categories of data (e.g. training, validation, test and production data);

— categories of data (e.g. as defined in ISO/IEC 19944-1);

— process for labelling data;

— intended use of the data;

— 資料資源，即在人工智慧系統生命週期的任何階段使用的資料；

— 工具資源 (如人工智慧演算法、模型或工具)；

— 系統和計算資源 (如用於開發和運作人工智慧模型的硬體、儲存資料和工具資源的設備)；

— 人力資源，即在人工智慧系統生命週期中，與組織角色相關且具備必要專業知識的人員 (如負責開發、銷售、訓練、運作和維護人工智慧系統的人員)。

資源可以由組織本身、其客戶或第三方提供。

其他資訊

資源的文件化還可以幫助決定資源是否可用，如果不可用，組織宜修訂人工智慧系統的設計規範或其部署要求。

B.4.3 資料資源

控制措施

作為資源識別的一部分，組織宜文件化有關人工智慧系統使用的資料資源之資訊。

實作指引

關於資料的文件化宜包括但不限於以下主題：

— 資料的來源；

— 資料的最後更新或修改日期 (如詮釋資料中的日期標籤)；

— 對於機器學習，資料的分類 (如訓練資料、驗證資料、測試資料和生產資料)；

— 資料類別 (如 ISO/IEC 19944-1 之定義)；

— 資料標記的流程；

— 資料的預期用途；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

- quality of data (e.g. as described in the ISO/IEC 5259 series2));
- applicable data retention and disposal policies;
- known or potential bias issues in the data;
- data preparation.

B.4.4 Tooling resources

Control

As part of resource identification, the organization should document information about the tooling resources utilized for the AI system.

Implementation guidance

Tooling resources for an AI system and particularly for machine learning, can include but are not limited to:

- algorithm types and machine learning models;
- data conditioning tools or processes;
- optimization methods;
- evaluation methods;
- provisioning tools for resources;
- tools to aid model development;
- software and hardware for AI system design, development and deployment.

Other information

ISO/IEC 23053 provides detailed guidance on the types, methods and approaches for various tooling resources for machine learning.

B.4.5 System and computing resources

Control

As part of resource identification, the organization should document information about the system and computing resources utilized for the AI system.

- 資料品質 (如在 ISO/IEC 5259 系列 2 的描述) ;
- 適用的資料留存和汰除政策 ;
- 資料中已知或潛在的偏差議題 ;
- 資料準備。

B.4.4 工具資源

控制措施

作為資源識別的一部分，組織宜文件化有關人工智慧系統使用的工具資源之資訊。

實作指引

人工智慧系統，尤其是機器學習的工具資源，可以包括但不限於：

- 演算法類型和機器學習模型；
- 資料調整工具或流程；
- 優化方法；
- 評估方法；
- 資源配置工具；
- 幫助模型開發的工具；
- 用於人工智慧系統設計、開發和部署的軟硬體。

其他資訊

ISO/IEC 23053 提供了有關機器學習的各種工具資源類型、方法和方法的詳細指引。

B.4.5 系統和運算資源

控制措施

作為資源識別的一部分，組織宜文件化有關人工智慧系統使用的系統和運算資源之資訊。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Implementation guidance

Information about system and computing resources for an AI system can include but is not limited to:

- resource requirements of the AI system (i.e. to help ensure the system can run on constrained resource devices);
- where the system and computing resources are located (e.g. on-premises, cloud computing or edge computing);
- processing resources (including network and storage);
- the impact of the hardware used to run the AI system workloads (e.g. the impact to the environment either through use or the manufacturing of the hardware or cost of using the hardware).

The organization should consider that different resources can be required to allow continual improvement of AI systems. Development, deployment and operation of the system can have different system needs and requirements.

NOTE ISO/IEC 22989 describes various system resource considerations.

B.4.6 Human resources

Control

As part of resource identification, the organization should document information about the human resources and their competences utilized for the development, deployment, operation, change management, maintenance, transfer and decommissioning, as well as verification and integration of the AI system.

Implementation guidance

The organization should consider the need for diverse expertise and include the types of roles necessary for the system. For example, the organization can include specific demographic groups related to data sets used to train machine learning models, if their inclusion is a necessary component of the system design. Necessary human resources can include but are not limited to:

- data scientists;
- roles related to human oversight of AI systems;

實作指引

關於人工智慧系統的系統和運算資源的資訊可以包括但不限於：

- 人工智慧系統的資源需求 (即確保系統能夠在受限資源設備上運作)；
- 系統和運算資源的位置 (如本地、雲端運算或邊緣運算)；
- 處理資源 (包括網路和儲存)；
- 用於運作人工智慧系統工作負載的硬體衝擊 (如通過使用或製造硬體對環境的衝擊或使用硬體的成本)。

為了實現人工智慧系統的持續改善，組織宜考量可能需要不同的資源。系統的開發、部署和運作可能有不同的系統需求和要求。

備考 ISO/IEC 22989 描述了各種系統資源的考慮因素。

B.4.6 人力資源

控制措施

作為資源識別的一部分，組織宜文件化有關在人力資源及其能力方面之資源，包括在人工智慧系統的開發、部署、運作、變更管理、維護、轉移和停止使用，以及驗證和整合中的使用情況。

實作指引

組織宜考慮多樣化專業知識的需求，並包括系統所需的角色類型。例如，如果特定人口群體的參與是系統設計的必要組成部分，組織可以包括與訓練機器學習模型的資料集相關的特定人口群體。必要的人力資源可以包括但不限於：

- 資料科學家；
- 與人為監管人工智慧系統相關的角色；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

— experts on trustworthiness topics such as safety, security and privacy;

— AI researchers and specialists, and domain experts relevant to the AI systems.

Different resources can be necessary at different stages of the AI system life cycle.

B.5 Assessing impacts of AI systems

B.5.1 Objective

To assess AI system impacts to individuals or groups of individuals, or both, and societies affected by the AI system throughout its life cycle.

B.5.2 AI system impact assessment process

Control

The organization should establish a process to assess the potential consequences for individuals or groups of individuals, or both, and societies that can result from the AI system throughout its life cycle.

Implementation guidance

Because AI systems potentially generate significant impact to individuals, groups of individuals, or both, and societies, the organization that provides and uses such systems should, based on the intended purpose and use of these systems, assess the potential impacts of these systems on these groups.

The organization should consider whether an AI system affects:

- the legal position or life opportunities of individuals;
- the physical or psychological well-being of individuals;
- universal human rights;
- societies.

The organization's procedures should include, but are not limited to:

- a) circumstances under which an AI system impact assessment should be performed, which can include, but are not limited to:

— 關於可信性主題的專家，如安全性、資安與隱私；

— 人工智慧研究人員和專家，以及與人工智慧系統相關的領域專家。

在人工智慧系統生命週期的不同階段，可能需要不同的資源。

B.5 人工智慧系統之衝擊評鑑

B.5.1 目標

評鑑人工智慧系統在其生命週期中對個人或群體，或二者，以及社會的衝擊。

B.5.2 人工智慧系統衝擊評鑑流程

控制措施

組織宜建立一個流程，評估人工智慧系統在其生命週期中可能對個人或群體，或二者，以及社會產生的潛在後果。

實作指引

由於人工智慧系統可能對個人、群體以及社會產生重大衝擊，提供和使用此類系統的組織宜根據這些系統的預期目的和用途，評鑑其對這些群體的潛在衝擊。

組織宜考慮人工智慧系統是否會影響：

- 個人的法律地位或生活機會；
- 個人的身體或心理健康；
- 普遍的人權；
- 社會。

組織的程序應包括但不限於：

- a) 宜在何種情況下進行人工智慧系統衝擊評鑑，這可能包括但不限於：

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

- | | |
|--|---|
| <p>1) criticality of the intended purpose and context in which the AI system is used or any significant changes to these;</p> <p>2) complexity of AI technology and the level of automation of AI systems or any significant changes to that;</p> <p>3) sensitivity of data types and sources processed by the AI system or any significant changes to that;</p> <p>b) elements that are part of the AI system impact assessment process, which can include:</p> <p>1) identification (e.g. sources, events and outcomes);</p> <p>2) analysis (e.g. consequences and likelihood);</p> <p>3) evaluation (e.g. acceptance decisions and prioritization);</p> <p>4) treatment (e.g. mitigation measures);</p> <p>5) documentation, reporting and communication (see 7.4, 7.5 and B.3.3);</p> <p>c) who performs the AI system impact assessment;</p> <p>d) how the AI system impact assessment can be utilized [e.g. how it can inform the design or use of the system (see B.6 and B.9), whether it can trigger reviews and approvals];</p> <p>e) individuals and societies that are potentially impacted based on the system's intended purpose, use and characteristics (e.g. assessment for individuals, groups of individuals or societies).</p> | <p>1) 人工智慧系統使用的預期目的和處境的關鍵性，或對這些內容的任何重大更改；</p> <p>2) 人工智慧技術的複雜性和人工智慧系統自動化程度，或對此的任何重大更改；</p> <p>3) 人工智慧系統處理的資料類型和來源的敏感性，或對此的任何重大更改；</p> <p>b) 人工智慧系統衝擊評鑑過程中的要素，這可能包括：</p> <p>1) 識別（如來源、事件和結果）；</p> <p>2) 分析（如後果和可能性）；</p> <p>3) 評估（如接受決策和優先序）；</p> <p>4) 處理（如緩解措施）；</p> <p>5) 文件化、報告和溝通（參見 7.4、7.5 和 B.3.3）；</p> <p>c) 負責進行人工智慧系統衝擊評鑑之人員；</p> <p>d) 如何利用人工智慧系統衝擊評鑑 [如系統設計或使用的告知方式（參見 B.6 和 B.9），以及是否會觸發審查和核可]；</p> <p>e) 根據系統的預期目的、用途和特徵，可能受到衝擊的個人和社會（如對個人、群體或社會的評鑑）。</p> |
|--|---|

Impact assessment should take various aspects of the AI system into account, including the data used for the development of the AI system, the AI technologies used and the functionality of the overall system.

The processes can vary based on the role of the organization and the domain of AI application and depending on the specific disciplines for which the impact is assessed (e.g. security, privacy and safety).

Other information

For some disciplines or organizations, detailed consideration of the impact on individuals or groups of individuals, or both, and societies is part of risk management, particularly in disciplines such as information security, safety and environmental

衝擊評鑑宜考慮人工智慧系統的各個方面，包括用於開發人工智慧系統的資料、人工智慧技術和整個系統的功能。

流程可能會根據組織的角色、人工智慧應用領域，以及進行影響評估的特定領域（例如安全性、隱私和安全）而有所不同。

其他資訊

對於某些領域或組織，對個人或群體以及社會衝擊的詳細考量是風險管理的一部分，尤其是在資訊安全、安全性和環境管理等領域中。組織宜決定作為此類風險管理過程一

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

management. The organization should determine if discipline-specific impact assessments performed as part of such a risk management process sufficiently integrate AI considerations for those specific aspects (e.g. privacy).

NOTE ISO/IEC 23894 describes how an organization can perform impact analyses for the organization itself, along with individuals or groups of individuals, or both, and societies, as part of an overall risk management process.

B.5.3 Documentation of AI system impact assessments

Control

The organization should document the results of AI system impact assessments and retain results for a defined period.

Implementation guidance

The documentation can be helpful in determining information that should be communicated to users and other relevant interested parties.

AI system impact assessments should be retained and updated, as needed, in alignment with the elements of an AI system impact assessment documented in B.5.2. Retention periods can follow organization retention schedules or be informed by legal requirements or other requirements.

Items that the organization should consider documenting can include, but are not limited to:

- the intended use of the AI system and any reasonable foreseeable misuse of the AI system;
- positive and negative impacts of the AI system to the relevant individuals or groups of individuals, or both, and societies;
- predictable failures, their potential impacts and measures taken to mitigate them;
- relevant demographic groups the system is applicable to;
- complexity of the system;
- the role of humans in relationships with system, including human oversight capabilities, processes and tools, available to avoid negative impacts;
- employment and staff skilling.

部分進行的領域特定衝擊評鑑是否充分整合人工智慧的考量因素 (如隱私)。

備考 ISO/IEC 23894 描述了組織如何在整體風險管理過程中對組織本身、個人或群體，以及社會進行衝擊分析。

B.5.3 人工智慧系統衝擊評鑑之文件化

控制措施

組織宜文件化人工智慧系統衝擊評鑑的結果，並於規定之期間內留存。

實作指引

文件化有助於決定宜向使用者和其他相關關注方傳達的資訊。

人工智慧系統衝擊評鑑宜根據 B.5.2 中記錄的人工智慧系統衝擊評鑑要素進行留存和更新。留存期限可以遵循組織的留存日程，或由法律要求或其他要求決定。

組織宜考量文件化的項目可以包括但不限於：

- 人工智慧系統的預期用途及其任何可預見的誤用；
- 人工智慧系統對相關個人或群體以及社會的正面和負面衝擊；
- 可預見的故障，其潛在衝擊以及所採取的緩解措施；
- 系統適用的相關人口群體；
- 系統的複雜性；
- 人類在與系統的關係中的角色，包括避免負面影響的人為監管能力、流程和工具；
- 就業和員工技能培訓。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

B.5.4 Assessing AI system impact on individuals or groups of individuals

Control

The organization should assess and document the potential impacts of AI systems to individuals or groups of individuals throughout the system's life cycle.

Implementation guidance

When assessing the impacts on individuals or groups of individuals, or both, and societies, the organization should consider its governance principles, AI policies and objectives. Individuals using the AI system or whose PII are processed by the AI system, can have expectations related to the trustworthiness of the AI system. Specific protection needs of groups such as children, impaired persons, elderly persons and workers should be taken into account. The organization should evaluate these expectations and consider the means to address them as part of the system impact assessment.

Depending on the scope of AI system purpose and use, areas of impact to consider as part of the assessment can include, but are not limited to:

- fairness;
- accountability;
- transparency and explainability;
- security and privacy;
- safety and health;
- financial consequences;
- accessibility;
- human rights.

Other information

Where necessary, the organization should consult experts (e.g. researchers, subject matter experts and users) to obtain a full understanding of potential impacts of the AI system on individuals or groups of individuals, or both, and societies.

B.5.4 人工智慧系統對個人或群體的衝擊評鑑

控制措施

組織宜評鑑並文件化人工智慧系統在其生命週期中對個人或群體的潛在衝擊。

實作指引

在評鑑對個人或群體，以及對社會的衝擊時，組織宜考量其治理原則、人工智慧政策和目標。使用人工智慧系統的個人或其個人可識別資訊 (PII) 被人工智慧系統處理的人可能對人工智慧系統的可信性有期望。宜考慮到諸如兒童、殘疾人、老年人和工人等群體的具體保護需求。組織宜評估這些期望，並考量將其作為系統衝擊評鑑的一部分。

根據人工智慧系統的目的和用途，衝擊評鑑中可考慮的領域可以包括但不限於：

- 公平性；
- 當責性；
- 透明性與可解釋性；
- 資安與隱私；
- 安全與健康；
- 財務後果；
- 可及性；
- 人權。

其他資訊

需要時，組織宜諮詢專家 (如研究人員、主題專家和使用 者)，以全面了解人工智慧系統對個人或群體，以及對社會的潛在衝擊。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

B.5.5 Assessing societal impacts of AI systems

Control

The organization should assess and document the potential societal impacts of their AI systems throughout their life cycle.

Implementation guidance

Societal impacts can vary widely depending on the organization's context and the types of AI systems. The societal impacts of AI systems can be both beneficial and detrimental. Examples of these potential societal impacts can include:

- environment sustainability (including the impacts on natural resources and greenhouse gas emissions);
- economic (including access to financial services, employment opportunities, taxes, trade and commerce);
- government (including legislative processes, misinformation for political gain, national security and criminal justice systems);
- health and safety (including access to healthcare, medical diagnosis and treatment, and potential physical and psychological harms);
- norms, traditions, culture and values (including misinformation that leads to biases or harms to individuals or groups of individuals, or both, and societies).

Other information

Development and use of AI systems can be computationally intensive with related impacts to environmental sustainability (e.g. greenhouse gas emissions due to increased power usage, impacts on water, land, flora and fauna). Likewise, AI systems can be used to improve the environmental sustainability of other systems (e.g. reduce greenhouse gas emissions related to buildings and transportation). The organization should consider the impacts of its AI systems in the context of its overall environmental sustainability goals and strategies.

The organization should consider how its AI systems can be misused to create societal harms and how they can be used to address historical harms. For example, can AI systems prevent access to financial services such as loans, grants, insurance and investments and likewise can AI systems improve access to these

B.5.5 人工智慧系統對社會的衝擊評鑑

控制措施

組織宜評鑑並文件化人工智慧系統在其生命週期中對社會的潛在衝擊。

實作指引

社會衝擊可能根據組織的背景和人工智慧系統的類型而有很大差異。人工智慧系統的社會衝擊可能既有利又有害。這些潛在社會衝擊的例子可以包括：

- 環境永續 (包括對自然資源和溫室氣體排放的影響)；
- 經濟 (包括金融服務的可及性、就業機會、稅收、貿易和商業)；
- 政府 (包括立法過程、政治利益的錯誤資訊、國家安全和刑事司法系統)；
- 健康與安全 (包括醫療保健的可及性、醫療診斷和治療，以及潛在的身體和心理傷害)；
- 規範、傳統、文化和價值觀 (包括導致偏見或對個人或群體，以及社會造成傷害的錯誤資訊)。

其他資訊

人工智慧系統的開發和使用可能需要大量計算資源，這與環境永續相關 (如由於增加的電力使用導致的溫室氣體排放，對水、土地、植物和動物的衝擊)。同樣，人工智慧系統可以用於改善其他系統的環境永續 (如減少與建築物和交通相關的溫室氣體排放)。組織宜考量其人工智慧系統在整體環境永續目標和策略中的衝擊。

組織宜考量人工智慧系統如何被濫用以造成社會危害，以及如何用於解決歷史上的危害。例如，人工智慧系統是否可以防止獲取金融服務 (如貸款、補助金、保險和投資)，以及人工智慧系統是否可以改善這些工具的可及性？

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

instruments?

AI systems have been used to influence the outcomes of elections and to create misinformation (e.g. deepfakes in digital media) that can lead to political and social unrest. Government's use of AI systems for criminal-justice purposes has exposed the risk of biases to societies, individuals or groups of individuals. The organization should analyse how actors can misuse AI systems and how the AI systems can reinforce unwanted historical social biases.

AI systems can be used to diagnose and treat illnesses and to determine qualifications for health benefits. AI systems are also deployed in scenarios where malfunctions can result in death or injury to humans (e.g. self-driving automobiles, human-machine teaming). The organization should consider both the positive and negative outcomes when using AI systems, such as in health and safety related scenarios.

NOTE ISO/IEC TR 24368 provides a high-level overview of ethical and societal concerns related to AI systems and applications.

B.6 AI system life cycle

B.6.1 Management guidance for AI system development

B.6.1.1 Objective

To ensure that the organization identifies and documents objectives and implements processes for the responsible design and development of AI systems.

B.6.1.2 Objectives for responsible development of AI system

Control

The organization should identify and document objectives to guide the responsible development of AI systems, and take those objectives into account and integrate measures to achieve them in the development life cycle.

Implementation guidance

The organization should identify objectives (see 6.2) that affect the AI system design and development processes. These objectives should be taken into account in the design and development processes. For example, if an organization defines "fairness" as one objective, this should be incorporated in the requirements specification, data acquisition, data

人工智慧系統已被用於影響選舉結果並創造錯誤資訊 (如數位媒體中的深度偽造)。這可能導致政治和社會動盪。政府將人工智慧系統用於刑事司法目的，已經暴露了對社會、個人或群體的偏見風險。組織宜分析行為者如何濫用人工智慧系統，以及人工智慧系統如何強化不希望的歷史社會偏見。

人工智慧系統可以用於診斷和治療疾病，並決定獲取健康福利的資格。人工智慧系統也被部署在故障可能導致人員死亡或受傷的情境中 (如自駕車、人機協作)。組織在使用人工智慧系統時，宜考量其正面和負面的結果，特別是在與健康和安全相關的情境中。

備考 ISO/IEC TR 24368 提供了有關人工智慧系統和應用的倫理和社會問題的高層次概述。

B.6 人工智慧系統生命週期

B.6.1 人工智慧系統開發的管理指導

B.6.1.1 目標

確保組織識別並文件化目標，並實施負責任的人工智慧系統設計和開發流程。

B.6.1.2 負責任人工智慧系統開發之目標

控制措施

組織宜識別並文件化目標，以引導負責任人工智慧系統的開發，並參照這些目標與整合相關措施以在開發生命週期中達到這些目標。

實作指引

組織宜識別影響人工智慧系統設計和開發過程的目標 (參見 6.2)。這些目標宜在設計和開發過程中被考慮。例如，如果組織將“公平性”定義為一個目標，這宜被納入要求規範、資料獲取、資料處理、模型訓練、驗證和確認等過程中。組織宜提供必要的要求和指導，以確保在各個

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

conditioning, model training, verification and validation, etc. The organization should provide requirements and guidelines as necessary to ensure that measures are integrated into the various stages (e.g. the requirement to use a specific testing tool or method to address unfairness or unwanted bias) to achieve such objectives.

Other information

AI techniques are being used to augment security measures such as threat prediction detection and prevention of security attacks. This is an application of AI techniques that can be used to reinforce security measures to protect both AI systems and conventional non-AI based software systems. Annex C provides examples of organizational objectives for managing risk, which can be useful in determining the objectives for AI system development.

B.6.1.3 Processes for responsible design and development of AI systems

Control

The organization should define and document the specific processes for the responsible design and development of the AI system.

Implementation guidance

Responsible development for AI system processes should include consideration of, without limitation, the following:

- life cycle stages (a generic AI system life cycle model is provided by ISO/IEC 22989, but the organization can specify their own life cycle stages);
- testing requirements and planned means for testing;
- human oversight requirements, including processes and tools, especially when the AI system can impact natural persons;
- at what stages AI system impact assessments should be performed;
- training data expectations and rules (e.g. what data can be used, approved data suppliers and labelling);
- expertise (subject matter domain or other) required or training for developers of AI systems or both;

階段整合措施 (如要求使用特定的測試工具或方法來解決不公平或不必要的偏見) 以達成這些目標。

其他資訊

人工智慧技術正在用於增強資安措施，例如威脅預測檢測和免於資安攻擊。這是一種人工智慧技術的應用，可以用於加強保護人工智慧系統和傳統非人工智慧軟體系統的資安措施。附錄 C 提供了管理風險的組織目標的範例，這對決定人工智慧系統開發的目標有所幫助。

B.6.1.3 負責任的人工智慧系統設計和開發流程

控制措施

組織宜定義並文件化負責任人工智慧系統設計和開發的具體流程。

實作指引

負責任的人工智慧系統開發過程宜包括但不限於以下事項之考量：

- 生命週期階段 (ISO/IEC 22989 提供了一個通用的人工智慧系統生命週期模型，但組織可以註明自己的生命週期階段)；
- 測試要求和規劃的測試方式；
- 人為監管要求，包括流程和工具，尤其是在人工智慧系統可能影響自然人的情況下；
- 宜在什麼階段進行人工智慧系統衝擊評鑑；
- 訓練資料的期望和規則 (如可以使用哪些資料，經核可的資料供應商和標記)；
- 人工智慧系統開發者所需的專業知識 (主題領域或其他)，或訓練需求，或兩者皆有；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

- release criteria;

— approvals and sign-offs necessary at various stages;

— change control;

— usability and controllability;

— engagement of interested parties.
- 發佈準則；

— 在各個階段所需的核准和簽核；

— 變更控制；

— 可用性和可控性；

— 關注方的參與。

The specific design and development processes depend on the functionality and the AI technologies that are intended to be used for the AI system.

具體的設計和開發過程取決於人工智慧系統預期使用的功能和人工智慧技術。

B.6.2 AI system life cycle

B.6.2 人工智慧系統生命週期

B.6.2.1 Objective

B.6.2.1 目標

To define the criteria and requirements for each stage of the AI system life cycle.

為人工智慧系統生命週期的每個階段定義準則和要求。

B.6.2.2 AI system requirements and specification

B.6.2.2 人工智慧系統要求與規範

Control

控制措施

The organization should specify and document requirements for new AI systems or material enhancements to existing systems.

組織宜為新人工智慧系統或對既有系統之重大增強進行註明並文件化需求。

Implementation guidance

實作指引

The organization should document the rationale for developing an AI system and its goals. Some of the factors that should be considered, documented and understood can include:

組織宜文件化開發人工智慧系統的理由及其目標。宜考量、文件化和理解的一些因素包括：

- a) why the AI system is to be developed, for example, is this driven by a business case, customer request or by government policy;

b) how the model can be trained and how data requirements can be achieved.
- a) 為什麼要開發人工智慧系統，例如，這是由業務需求、客戶請求還是政府政策驅動的；

b) 模型如何進行訓練以及如何達到資料要求。

AI system requirements should be specified and should span the entire AI system life cycle. Such requirements should be revisited in cases where the developed AI system is unable to operate as intended or new information arises that can be used to change and to improve the requirements. For instance, it can become unfeasible from a financial perspective to develop the AI system.

人工智慧系統要求宜涵蓋整個人工智慧系統生命週期。在開發的人工智慧系統無法按預期運作或出現可以用於更改和改進要求的新資訊時，宜重新檢討這些要求。例如，從財務角度來看，開發人工智慧系統可能變得不可行。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Other information

The processes for describing the AI system life cycle are provided by ISO/IEC 5338. For more information about human-centred design for interactive systems, see ISO 9241-210.

B.6.2.3 Documentation of AI system design and development

Control

The organization should document the AI system design and development based on organizational objectives, documented requirements and specification criteria.

Implementation guidance

There are many design choices necessary for an AI system, including, but not limited to:

- machine learning approach (e.g. supervised vs. unsupervised);
- learning algorithm and type of machine learning model utilized;
- how the model is intended to be trained and which data quality (see B.7);
- evaluation and refinement of models;
- hardware and software components;
- security threats considered throughout the AI system life cycle; security threats specific to AI systems include data poisoning, model stealing or model inversion attacks;
- interface and presentation of outputs;
- how humans can interact with the system;
- interoperability and portability considerations.

There can be multiple iterations between design and development, but documentation on the stage should be maintained and a final system architecture documentation should be available.

Other information

For more information about human-centred design for interactive systems, see ISO 9241-210.

其他資訊

描述人工智慧系統生命週期的過程由 ISO/IEC 5338 提供。關於互動系統以人為中心設計的更多資訊，參見 ISO 9241-210。

B.6.2.3 人工智慧系統設計與開發的文件化

控制措施

組織宜根據組織目標、文件化的要求和規範準則，文件化人工智慧系統的設計與開發流程。

實作指引

人工智慧系統的設計需要做出許多選擇，包括但不限於：

- 機器學習方法 (如監督式學習與非監督式學習)；
- 使用的學習演算法和機器學習模型類型；
- 模型的訓練方式以及資料品質 (參見 B.7)；
- 模型的評估和改進；
- 硬體和軟體組件；
- 在人工智慧系統生命週期中考慮的資安威脅；針對人工智慧系統的特定資安威脅包括資料汙染、模型竊取或模型反轉攻擊；
- 輸出的界面和呈現方式；
- 人類如何與系統互動；
- 互操作性和可攜性之考量。

設計和開發之間可能會有多次迭代，但宜保持階段的文件化，並宜提供最終的系統架構文件化。

其他資訊

關於互動系統以人為中心設計的更多資訊，參見 ISO 9241-210。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

B.6.2.4 AI system verification and validation

Control

The organization should define and document verification and validation measures for the AI system and specify criteria for their use.

Implementation guidance

The verification and validation measures can include, but are not limited to:

- testing methodologies and tools;
- selection of test data and their representation of the intended domain of use;
- release criteria requirements.

The organization should define and document evaluation criteria such as, but not limited to:

- a plan to evaluate the AI system components and the whole AI system for risks related to impacts on individuals or groups of individuals, or both, and societies;
- the evaluation plan can be based on, for example:

- reliability and safety requirements of the AI system, including acceptable error rates for the AI system performance;
- responsible AI system development and use objectives such as those in B.6.1.2 and B.9.3;
- operational factors such as quality of data, intended use, including acceptable ranges of each operational factor;
- any intended uses which can require more rigorous operational factors to be defined, including different acceptable ranges for operational factors or lower error rates;

— the methods, guidance or metrics to be used to evaluate whether relevant interested parties who make decisions or are subject to decisions based on the AI system outputs can adequately interpret the AI system outputs. The frequency of evaluation should be determined and can be based upon results from an AI system impact assessment;

B.6.2.4 人工智慧系統的驗證與確認

控制措施

組織宜為人工智慧系統定義並文件化驗證與確認措施，並註明其使用標準。

實作指引

驗證和確認措施可以包括但不限於：

- 測試方法和工具；
- 測試資料的選擇及其對預期使用領域的代表性；
- 發佈準則要求。

組織宜定義並文件化評估準則，例如但不限於：

- 評估人工智慧系統組件和整個人工智慧系統對個人或群體，或兩者，以及對社會的衝擊風險的計劃；
- 評估計劃可以基於，例如：
 - 人工智慧系統的可靠性和安全性要求，包括人工智慧系統性能的可接受錯誤率；
 - 如 B.6.1.2 和 B.9.3 中的負責任的人工智慧系統開發和使用目標；
 - 操作因素，例如資料品質、預期用途，包括每個操作因素的可接受範圍；
 - 任何可能需要更嚴格操作因素定義的預期用途，包括不同操作因素的可接受範圍或更低的錯誤率；
- 用於評估相關關注方是否能夠充分解釋基於人工智慧系統輸出進行決策或受其影響的決策的方法、指導或指標。評估的頻率宜根據人工智慧系統衝擊評鑑的結果來決定；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

— any acceptable factors that can account for an inability to meet a target minimum performance level, especially when the AI system is evaluated for impacts on individuals or groups of individuals, or both, and societies (e.g. poor image resolution for computer vision systems or background noise affecting speech recognition systems). Mechanisms to deal with poor AI system performance as a result of these factors should also be documented.

The AI system should be evaluated against the documented criteria for evaluation.

Where the AI system cannot meet the documented criteria for evaluation, especially against responsible AI system development and use objectives (see B.6.1.2 and B.9.3), the organization should reconsider or manage the deficiencies of the intended use of the AI system, its performance requirements and how the organization can effectively address the impacts to individuals or groups of individuals, or both, and societies.

NOTE Further information on how to deal with robustness of neural networks can be found in ISO/IEC TR 24029-1.

B.6.2.5 AI system deployment

Control

The organization should document a deployment plan and ensure that appropriate requirements are met prior to deployment.

Implementation guidance

AI systems can be developed in various environments and deployed in others (such as developed on premises and deployed using cloud computing) and the organization should take these differences into account for the deployment plan. The organization should also consider whether components are deployed separately (e.g. software and model can be deployed independently). Additionally, the organization should have a set of requirements to be met prior to release and deployment (sometimes referred to as “release criteria”). This can include verification and validation measures that are to be passed, performance metrics that are to be met, user testing to be completed, as well as management approvals and sign-offs to be obtained. The deployment plan should take into account the perspectives of and impacts to relevant interested parties.

— 任何可以解釋未達到目標最低性能等級的可接受因素，尤其是在評估人工智慧系統對個人或群體，或對社會的影響時（如電腦視覺系統的圖像分辨率差或背景噪音影響語音識別系統）。宜記錄處理由於這些因素導致的人工智慧系統性能不佳的機制。

宜根據文件化的評估準則對人工智慧系統進行評估。

如果人工智慧系統無法滿足記錄的評估準則，尤其是無法滿足負責任的人工智慧系統開發和使用目標（參見 B.6.1.2 和 B.9.3），組織宜重新考慮或管理人工智慧系統預期用途的缺陷、其性能要求以及組織如何有效應對個人或群體，或兩者，或對社會的衝擊。

備考 關於如何處理神經網路的穩健性，更多資訊見 ISO/IEC TR 24029-1。

B.6.2.5 人工智慧系統部署

控制措施

組織宜文件化部署計劃，並確保在部署前滿足相關要求。

實作指引

人工智慧系統可以在各種環境中開發，並在其他環境中部署（如在本地開發並使用雲端運算進行部署）。組織宜在部署計劃中考量這些差異。組織亦宜考量是否需要分別部署組件（如軟體和模型可以獨立部署）。此外，組織宜制定一套在發布和部署前需要滿足的要求（有時稱為“發布準則”）。這可以包括需要通過的驗證和確認措施、需要達到的性能指標、需要完成的使用者測試，以及需要獲得的管理層核准和簽核。部署計劃宜考量相關關注方的觀點及其衝擊。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

B.6.2.6 AI system operation and monitoring

Control

The organization should define and document the necessary elements for the ongoing operation of the AI system. At the minimum this should include system and performance monitoring, repairs, updates and support.

Implementation guidance

Each minimum activity for operation and monitoring can take account of various considerations. For example:

— System and performance monitoring can include monitoring for general errors and failures, as well as for whether the system is performing as expected with production data. Technical performance criteria can include success rates in resolving problems or in achieving tasks, or confidence rates. Other criteria can be related to meeting commitment or expectation and needs of interested parties, including, for example, ongoing monitoring to ensure compliance with customer requirements or applicable legal requirements.

— Some deployed AI systems evolve their performance as a result of ML, where production data and output data are used to further train the ML model. Where continuous learning is used, the organization should monitor the performance of the AI system to ensure that it continues to meet its design goals and operates on production data as intended.

— The performance of some AI systems can change even if such systems do not use continuous learning, usually due to concept or data drift in production data. In such cases, monitoring can identify the need for retraining to ensure that the AI system continues to meet its design goals and operates on production data as intended. More information can be found in ISO/IEC 23053.

— Repairs can include responses to errors and failures in the system. The organization should have processes in place for the response and repair of these issues. Additionally, updates can be necessary as the system evolves or as critical issues are identified, or as the result of externally identified issues (e.g. non-compliance with customer expectations or legal requirement). There should be processes in place for updating the system including components affected, update schedule, information to users on what is included in the update.

B.6.2.6 人工智慧系統的運作與監控

控制措施

組織宜定義並文件化人工智慧系統持續運作所需的要素。至少宜包括系統和性能監控、維修、更新和支援。

實作指引

運作和監督的每項基本活動都可以考慮各種因素。例如：

— 系統和性能監督可以包括對一般錯誤和故障之監督，以及系統在生產資料下是否按預期執行的監督。技術性能標準可以包括解決問題或完成任務的成功率，或可信率。其他標準可能與滿足關注方的承諾或期望和需求有關，例如持續監督以確保符合客戶要求或適用的法律要求。

— 一些已部署的人工智慧系統由於機器學習而提升性能，其中生產資料和輸出資料用於進一步訓練機器學習模型。在使用連續學習的情況下，組織宜監督人工智慧系統的性能，以確保它繼續達到設計目標並按預期在生產資料上運作。

— 即使某些人工智慧系統不使用連續學習，其性能也可能發生變化，通常是由於生產資料中的概念或資料漂移。在這種情況下，監督可以識別重新訓練的需求，以確保人工智慧系統繼續達到設計目標並按預期在生產資料上運作。更多資訊見 ISO/IEC 23053。

— 維修可以包括對系統中錯誤和故障的響應。組織宜有應對和修復這些問題的流程。此外，隨著系統的發展或關鍵問題的識別，或者外部識別的問題（如不符合客戶期望或法律要求），可能需要進行更新。宜有系統更新的流程，包括受影響的組件、更新時間表，以及向使用者提供的更新內容資訊。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

— System updates can also include changes in the system operations, new or modified intended uses, or other changes in system functionality. The organization should have procedures in place to address operational changes, including communication to users.

— Support for the system can be internal, external or both, depending on the needs of the organization and how the system was acquired. Support processes should consider how users can contact the appropriate help, how issues and incidents are reported, support service level agreements and metrics.

— Where AI systems are being used for purposes other than those for which they were designed or in ways that were not anticipated, the appropriateness of such uses should be considered.

— AI-specific information security threats related to the AI systems applied and developed by the organization should be identified. AI-specific information security threats include, but are not limited to data poisoning, model stealing and model inversion attacks.

Other information

The organization should consider operational performance that can affect interested parties and consider this when designing and determining performance criteria.

Performance criteria for AI systems in operation should be determined by the task under consideration, such as classification, regression, ranking, clustering or dimensionality reduction.

Performance criteria can include statistical aspects such as error rates and processing duration. For each criterion, the organization should identify all relevant metrics as well as interdependences between metrics. For each metric, the organization should consider acceptable values based on, for example, domain expert's recommendations and analysis of expectations of interested parties relative to existing non-AI practices.

For example, an organization can determine that the $F1$ score is an appropriate performance metric based on its assessment of the impact of false positives and false negatives, as described in ISO/IEC TS 4213. The organization can then establish an $F1$ value that the AI system is expected to meet. It should be evaluated if these issues can be handled by existing measures. If that is not the case, changes to existing measures should be considered or additional measures should be

— 系統更新還可以包括系統運作中的變更、新的或修改的預期用途或系統功能的其他變更。組織宜有處理運作變更的程序，包括向使用者的溝通。

— 根據組織的需求以及系統的獲取方式，系統支持可以是內部的、外部的或兩者兼有。支持流程宜考慮使用者如何聯繫適當的幫助、如何通報問題和事故、支持服務水準協議和指標。

— 如果人工智慧系統被用於設計之外的用途或以未預期的方式使用，宜考慮這些用途的適當性。

— 宜識別與組織應用和開發的人工智慧系統相關的人工智慧特定資訊安全威脅。人工智慧特定的資訊安全威脅包括但不限於資料汙染、模型竊取和模型反轉攻擊。

其他資訊

組織宜考慮影響關注方的運作性能，並在設計和決定性能準則時將其納入考慮。

運作中人工智慧系統的性能準則宜由考慮中的任務決定，如分類、回歸、排序、聚類或維度縮減。

性能準則可以包括統計方面，如錯誤率和處理時間。對於每個標準，組織宜識別所有相關的指標以及指標之間的相互依賴性。對於每個指標，組織宜根據例如領域專家的建議和對關注方期望的分析，考慮可接受的值，以現有的非人工智慧作法為基準。

例如，組織可以根據對假陽性和假陰性影響的評估，如 ISO/IEC TS 4213 中所述，決定 $F1$ 分數是一個適當的性能指標。然後，組織可以設立人工智慧系統應達到的 $F1$ 值。宜評估是否可以通過現有措施處理這些問題。如果不行，則宜考慮更改現有措施或定義其他措施以檢測和處理這些問題。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

defined to detect and handle these issues.

The organization should consider the performance of non-AI systems or processes in operation and use them as potentially relevant context when establishing performance criteria.

The organization should additionally ensure that the means and processes used to evaluate the AI system, including, where applicable, the selection and management of evaluation data, improve the completeness and the reliability in assessment of its performance with respect to the defined criteria.

Development of performance assessment methodologies can be based on criteria, metrics and values. These should inform the amount of data and the types of processes used in the assessment and the roles and expertise of personnel that carries out the assessment.

Performance assessment methodologies should reflect attributes and characteristics of operation and use as closely as possible to ensure that assessment results are useful and relevant. Some aspects of performance assessment can require controlled introduction of erroneous or spurious data or processes to assess impact on performance.

The quality model in ISO/IEC 25059 can be used to define performance criteria.

B.6.2.7 AI system technical documentation

Control

The organization should determine what AI system technical documentation is needed for each relevant category of interested parties, such as users, partners, supervisory authorities, and provide the technical documentation to them in the appropriate form.

Implementation guidance

The AI system technical documentation can include, but is not limited to the following elements:

- a general description of the AI system including its intended purpose;
- usage instructions;
- technical assumptions about its deployment and operation (run-time environment, related software and hardware capabilities, assumptions made on data, etc.);

組織宜考慮運作中非人工智慧系統或流程的性能，並在建立性能準則時將其作為相關背景參考。

此外，組織宜確保用於評估人工智慧系統的方法和流程，包括在適用情況下，評估資料的選擇和管理，改進其相對於定義準則的性能評估的完整性和可靠性。

性能評估方法的開發可以基於標準、指標和數值。這些宜指導評估中使用的資料量和流程類型以及進行評估的人員的角色和專業知識。

性能評估方法宜盡可能地反映運作和使用的屬性和特徵，以確保評估結果有用且相關。性能評估的一些方面可能需要有控制地引入錯誤或虛假資料或流程，以評估其對性能的影響。

ISO/IEC 25059中的品質模型可以用於定義性能標準。

B.6.2.7 人工智慧系統技術文件化

控制措施

組織宜決定每個相關關注方（如使用者、合作夥伴、監管機構）所需的人工智慧系統技術文件化，並以適當形式向他們提供技術文件化。

實作指引

人工智慧系統技術文件化可以包括但不限於以下要素：

- 人工智慧系統的一般描述，包括其預期用途；
- 使用說明；
- 關於其部署和運作的技術假設（運作環境、相關軟體能力、對資料的假設等）；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

— technical limitations (e.g. acceptable error rates, accuracy, reliability, robustness);

— monitoring capabilities and functions that allow users or operators to influence the system operation.

Documentation elements related to all AI system life cycle stages (as defined in ISO/IEC 22989) can include, but are not limited to:

— design and system architecture specification;

— design choices made and quality measures taken during the system development process;

— information about the data used during system development;

— assumptions made and quality measures taken on data quality (e.g. assumed statistical distributions);

— management activities (e.g. risk management) taken during development or operation of the AI system;

— verification and validation records;

— changes made to the AI system when it is in operation;

— impact assessment documentation as described in B.5.

The organization should document technical information related to the responsible operation of the AI system. This can include, but is not limited to:

— documenting a plan for managing failures. This can include for example, the need to describe a rollback plan for the AI system, turning off features of the AI system, an update process or a plan for notifying customers, users, etc. of changes to the AI system, updated information on system failures and how these can be mitigated;

— documenting processes for monitoring the health of the AI system (i.e. the AI system operates as intended and within its normal operating margins, also referred to as observability) and processes for addressing AI system failures;

— 技術限制 (如可接受的錯誤率、精度、可靠性、穩健性)；

— 監督功能，允許使用者或操作員影響系統運作的功能。

與所有人工智慧系統生命週期階段 (如 ISO/IEC 22989 中定義的) 相關的文件化要素可以包括但不限於：

— 設計和系統架構規範；

— 設計選擇和在系統開發過程中採取的品質措施；

— 在系統開發過程中使用的資料資訊；

— 關於資料品質所做的假設和採取的品質措施 (如假設的統計分佈)；

— 在人工智慧系統開發或運作期間採取的管理活動 (如風險管理)；

— 驗證和確認記錄；

— 人工智慧系統運作期間進行的變更；

— B.5 中描述的衝擊評鑑文件化。

組織宜文件化與人工智慧系統負責運作相關的技術資訊。這可以包括但不限於：

— 文件化故障管理計劃。例如，這可以包括描述人工智慧系統反轉計劃的需求、關閉人工智慧系統功能的計劃、更新過程或通知客戶、使用者等有關人工智慧系統變更的計劃，更新有關系統故障的資訊以及如何減輕這些故障的影響；

— 文件化監督人工智慧系統健康狀況 (即人工智慧系統按預期運作並在其正常運作範圍內運作，也稱為可觀察性) 和處理人工智慧系統缺失的過程；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

— documenting standard operating procedures for the AI system, including which events should be monitored and how event logs are prioritized and reviewed. It can also include how to investigate failures and the prevention of failures;

— documenting the roles of personnel responsible for operation of the AI system as well as those responsible for accountability of the system use, especially in relation to handling the effects of AI system failures or managing updates to the AI system;

— documenting system updates like changes in the system operations, new or modified intended uses, or other changes in system functionality.

The organization should have procedures in place to address operational changes including communication to users and internal evaluations on the type of change.

Documentation should be up to date and accurate. Documentation should be approved by the relevant management within the organization.

When provided as part of the user documentation, the controls provided in Table A.1 should be taken into account.

B.6.2.8 AI system recording of event logs

Control

The organization should determine at which phases of the AI system life cycle, record keeping of event logs should be enabled, but at the minimum when the AI system is in use.

Implementation guidance

The organization should ensure logging for AI systems it deploys to automatically collect and record event logs related to certain events that occur during operation. Such logging can include but is not limited to:

— traceability of the AI system's functionality to ensure that the AI system is operating as intended;

— detection of the AI system's performance outside of the AI system's intended operating conditions that can result in undesirable performance on production data or impacts to relevant interested parties through monitoring of the operation of the AI system.

— 文件化人工智慧系統的標準操作程序，包括宜監督哪些事件以及如何優先處理和審查事件日誌。這還可以包括如何調查故障以及預防故障；

— 文件化負責人工智慧系統運作的人員角色以及負責掌管系統使用責任的人員角色，尤其是與處理人工智慧系統故障的影響或管理人工智慧系統更新相關的角色；

— 文件化系統更新，如系統運作中的變更、新的或修改的預期用途或系統功能的其他變更。

組織宜有應對運作變更的程序，包括向使用者的溝通和對變更類型的內部評估。

宜保持最新且準確之文件化。文件化應經由組織內相關管理層核可。

在作為文件化的一部分提供給使用者時，宜考慮表 A.1 中提供的控制措施。

B.6.2.8 人工智慧系統事件日誌紀錄

控制措施

組織宜決定在人工智慧系統生命週期的哪些階段宜啟用事件日誌紀錄，但至少在人工智慧系統使用時應啟用。

實作指引

組織宜確保其部署的人工智慧系統具有自動收集和記錄事件日誌的功能，這些日誌與運作過程中發生的某些事件相關。此類日誌記錄可以包括但不限於：

— 人工智慧系統功能的可追溯性，以確保人工智慧系統按預期運作；

— 通過監督人工智慧系統的運作情況，檢測人工智慧系統性能是否超出預期的運作條件，這可能導致在生產資料上出現不理想的性能，或對相關關注方產生影響。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

AI system event logs can include information, such as the time and date each time the AI system is used, the production data on which the AI system operates on, the outputs that fall out of the range of the intended operation of the AI system, etc.

Event logs should be kept for as long as required for the intended use of the AI system and within the data retention policies of the organization. Legal requirements related to data retention can apply.

Other information

Some AI systems, such as biometric identification systems, can have additional logging requirements depending on jurisdiction. Organizations should be aware of these requirements.

B.7 Data for AI systems

B.7.1 Objective

To ensure that the organization understands the role and impacts of data in AI systems in the application and development, provision or use of AI systems throughout their life cycles.

B.7.2 Data for development and enhancement of AI system

Control

The organization should define, document and implement data management processes related to the development of AI systems.

Implementation guidance

Data management can include various topics such as, but not limited to:

- privacy and security implications due to the use of data, some of which can be sensitive in nature;
- security and safety threats that can arise from data dependent AI system development;
- transparency and explainability aspects including data provenance and the ability to provide an explanation of how data are used for determining an AI system's output if the system requires transparency and explainability;

人工智慧系統事件日誌可以包括以下資訊，如每次使用人工智慧系統的時間和日期、人工智慧系統運作的生產資料、超出人工智慧系統預期運作範圍的輸出等。

事件日誌宜根據人工智慧系統的預期用途和組織的資料留存政策進行留存。法律要求的資料留存相關規定可能適用。

其他資訊

某些人工智慧系統，如生物識別識別系統，根據不同司法管轄區可能有額外的日誌紀錄要求。組織宜了解這些要求。

B.7 人工智慧系統之資料

B.7.1 目標

確保組織了解資料在人工智慧系統中的角色及其在應用、開發、提供或使用人工智慧系統的流程中對其生命週期的影響。

B.7.2 用於人工智慧系統開發與增強型之資料

控制措施

組織宜定義、文件化並實作與人工智慧系統開發相關的資料管理流程。

實作指引

資料管理可以包括各種主題，如但不限於：

- 由於使用資料而引發的隱私和資安隱憂，其中一些資料可能具有敏感性質；
- 由於依賴資料的人工智慧系統開發而產生的資安及安全性威脅；
- 透明性和可解釋性方面，包括資料來源，以及在系統需要透明性和可解釋性時，能夠解釋資料如何用於決定人工智慧系統輸出；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

— representativeness of training data compared to operational domain of use;

— accuracy and integrity of the data.

NOTE Detailed information of AI system life cycle and data management concepts is provided by ISO/IEC 22989.

B.7.3 Acquisition of data

Control

The organization should determine and document details about the acquisition and selection of the data used in AI systems.

Implementation guidance

The organization can need different categories of data from different sources depending on the scope and use of their AI systems. Details for data acquisition can include:

- categories of data needed for the AI system;
- quantity of data needed;
- data sources (e.g. internal, purchased, shared, open data, synthetic);
- characteristics of the data source (e.g. static, streamed, gathered, machine generated);
- data subject demographics and characteristics (e.g. known or potential biases or other systematic errors);
- prior handling of the data (e.g. previous uses, conformity with privacy and security requirements);
- data rights (e.g. PII, copyright);
- associated metadata (e.g. details of data labelling and enhancing);
- provenance of the data.

Other information

The data categories and a structure for the data use in ISO/IEC 19944-1 can be used to document details about data acquisition and use.

— 訓練資料相對於運作領域的代表性；

— 資料的準確性和完整性。

備考 ISO/IEC 22989 提供了有關人工智慧系統生命週期和資料管理概念的詳細資訊。

B.7.3 資料之獲取

控制措施

組織宜決定並文件化有關人工智慧系統中使用之資料獲取與選擇的詳細資訊。

實作指引

根據人工智慧系統的範圍和用途，組織可能需要從不同來源獲取不同類別的資料。資料獲取的詳細資訊可以包括：

- 人工智慧系統所需的資料類別；
- 所需的資料量；
- 資料來源 (如內部資料、購買資料、共享資料、開放資料、合成資料)；
- 資料來源的特徵 (如靜態資料、串流資料、收集資料、機器生成資料)；
- 資料對象的人口統計和特徵 (如已知或潛在的偏見或其他系統性錯誤)；
- 資料前處理 (如先前使用情況、是否符合隱私和資安要求)；
- 資料權利 (如個人識別資訊PII、版權)；
- 相關詮釋資料 (如資料標記和增強的詳細資訊)；
- 資料的來源。

其他資訊

ISO/IEC 19944-1 中的資料類別和資料使用結構可用於記錄有關資料獲取和使用的詳細資訊。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

B.7.4 Quality of data for AI systems

Control

The organization should define and document requirements for data quality and ensure that data used to develop and operate the AI system meet those requirements.

Implementation guidance

The quality of data used to develop and operate AI systems potentially has significant impacts on the validity of the system's outputs. ISO/IEC 25024 defines data quality as the degree to which the characteristics of data satisfy stated and implied needs when used under specified conditions. For AI systems that use supervised or semi-supervised machine learning, it is important that the quality of training, validation, test and production data are defined, measured and improved to the extent possible, and the organization should ensure that the data are suitable for its intended purpose. The organization should consider the impact of bias on system performance and system fairness and make such adjustments as necessary to the model and data used to improve performance and fairness so they are acceptable for the use case.

Other information

Additional information regarding data quality is available in the ISO/IEC 5259 series2) on data quality for analytics and ML. Additional information regarding different forms of bias in data used in AI systems is available in ISO/IEC TR 24027.

B.7.5 Data provenance

Control

The organization should define and document a process for recording the provenance of data used in its AI systems over the life cycles of the data and the AI system.

Implementation guidance

According to ISO 8000-2, a record of data provenance can include information about the creation, update, transcription, abstraction, validation and transferring of the control of data. Additionally, data sharing (without transfer of control) and data transformations can be considered under data provenance.

B.7.4 人工智慧系統資料品質

控制措施

組織宜定義並文件化資料品質之要求，並確保用於開發和運行人工智慧系統的資料符合這些要求。

實作指引

用於開發和運作人工智慧系統的資料品質對系統輸出的有效性可能有重大影響。ISO/IEC 25024 將資料品質定義為在特定條件下使用時，資料特徵滿足明示和隱含需求的程度。對於使用監督式或半監督式機器學習的人工智慧系統，重要的是定義、測量和盡可能提高訓練、驗證、測試和生產資料的品質，並且組織宜確保這些資料適合其預期用途。組織宜考慮偏見對系統性能和系統公平性的影響，並根據需要對模型和資料進行調整，以提高性能和公平性，使其適合於案例。

其他資訊

有關資料品質的其他資訊，可參見 ISO/IEC 5259 系列中的分析和機器學習資料品質。ISO/IEC TR 24027 中提供了有關人工智慧系統中使用資料的不同形式偏見的額外資訊。

B.7.5 資料來歷

控制措施

組織宜對人工智慧系統中的資料，在其資料和人工智慧系統之生命週期中，定義並文件化資料來歷之流程。

實作指引

根據 ISO 8000-2，資料來歷的記錄可以包括有關資料創建、更新、轉錄、抽象、驗證和控制轉移的資訊。此外，資料共享（不轉移控制權）和資料轉換也可以被視為資料來歷的一部分。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Depending on factors such as the source of the data, its content and the context of its use, organizations should consider whether measures to verify the provenance of the data are needed.

B.7.6 Data preparation

Control

The organization shall define and document its criteria for selecting data preparations and the data preparation methods to be used.

Implementation guidance

Data used in an AI system ordinarily needs preparation to make it usable for a given AI task. For example, machine learning algorithms are sometimes intolerant of missing or incorrect entries, non-normal distribution and widely varying scales. Preparation methods and transforms can be used to increase the quality of the data. Failure to properly prepare the data can potentially lead to AI system errors. Common preparation methods and transformations for data used in AI systems include:

- statistical exploration of the data (e.g. distribution, mean, median, standard deviation, range, stratification, sampling) and statistical metadata (e.g. data documentation initiative (DDI) specification[28]);
- cleaning (i.e. correcting entries, dealing with missing entries);
- imputation (i.e. methods for filling in missing entries);
- normalization;
- scaling;
- labelling of the target variables;
- encoding (e.g. converting categorical variables to numbers).

For a given AI task, the organization should document its criteria for selecting specific data preparation methods and transforms as well as the specific methods and transforms used in the AI task.

NOTE For additional information on data preparation specific to machine learning see the ISO/IEC 5259 series2) and ISO/IEC 23053.

根據資料來歷、內容及其使用情況等因素，組織宜考慮是否需要採取措施來驗證資料來歷。

B.7.6 資料準備

控制措施

組織宜定義並文件化其選擇之資料準備和資料準備方法的準則。

實作指引

在人工智慧系統中使用的資料通常需要進行準備，以使其適用於特定的人工智慧任務。例如，機器學習算法有時無法容忍缺失或錯誤的條目、非常態分佈和尺度差異很大的資料。可以使用準備方法和轉換來提高資料的品質。如果資料未能正確準備，可能會導致人工智慧系統故障。常見的人工智慧系統資料準備和轉換方法包括：

- 資料的統計探索（如分佈、均值、中位數、標準差、範圍、分層、採樣）和統計詮釋資料（如資料文件倡議 (DDI) 規範 [28]）；
- 清理（即修正條目、處理缺失條目）；
- 補缺失值（即填補缺失條目的方法）；
- 正規化；
- 比例調整；
- 目標變量的標記；
- 編碼（例如，將類別變量轉換為數字）。

對於特定的人工智慧任務，組織宜文件化選擇特定資料準備方法和轉換的標準以及在人工智慧任務中使用的具體方法和轉換。

備考 有關機器學習資料準備的更多資訊，請參見 ISO/IEC 5259 系列和 ISO/IEC 23053。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

B.8 Information for interested parties

B.8.1 Objective

To ensure that relevant interested parties have the necessary information to understand and assess the risks and their impacts (both positive and negative).

B.8.2 System documentation and information for users

Control

The organization should determine and provide the necessary information to users of the system.

Implementation guidance

Information about the AI system can include both technical details and instructions, as well as general notifications to users that they are interacting with an AI system, depending on the context. This can also include the system itself, as well as potential outputs of the system (e.g. notifying users that an image is created by AI).

Although AI systems can be complex, it is critical that users are able to understand when they are interacting with an AI system, how the system works. Users also need to understand its intended purpose and intended uses, its potential to cause harm or benefit the user. Some system documentation can necessarily be targeted for more technical uses (e.g. system administrators), and the organization should understand the needs of different interested parties and what understandability can mean to them. The information should also be accessible, both in terms of ease of use in finding it, as well as for users who can need additional accessibility features.

Information that can be provided to users include, but are not limited to:

- purpose of the system;
- that the user is interacting with an AI system;
- how to interact with the system;
- how and when to override the system;
- technical requirements for system operation, including the computational resources needed, and limitations of the system as well as its expected lifetime;

B.8 關注方資訊

B.8.1 目標

確保相關關注方擁有必要之資訊，以瞭解和評鑑風險及其衝擊（包括正面和負面）。

B.8.2 系統文件化與使用者資訊

控制措施

組織宜決定並向系統的使用者提供必要之資訊。

實作指引

關於人工智慧系統的資訊可以包括技術細節和說明，也可以包括根據情況向使用者發出的一般通知，告知他們正在與人工智慧系統互動。這還可以包括系統本身以及系統的潛在輸出（例如，通知使用者某個圖像是由人工智慧創建的）。

雖然人工智慧系統可能很複雜，但至關重要的是，使用者必須能夠了解何時他們正在與人工智慧系統互動，以及系統的工作原理。使用者還需要了解其預期用途和使用目的，以及它對使用者可能造成的危害或帶來的利益。某些系統文件化可能專門針對更技術性的用途（例如系統管理員），組織宜了解不同關注方的需求以及理解對他們意味著什麼。這些資訊還應易於獲取，包括在查找方面的易用性，以及對於需要額外可及性功能的使用者來說，宜提供相應的可及性功能。

可以向使用者提供的資訊包括但不限於：

- 系統的目的；
- 使用者正在與人工智慧系統互動；
- 如何與系統互動；
- 如何以及何時覆寫系統；
- 系統運作的技術要求，包括所需的運算資源、系統的限制以及其預期壽命；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

- needs for human oversight;
 - information about accuracy and performance;
 - relevant information from the impact assessment, including potential benefits and harms, particularly if they are applicable in specific contexts or certain demographic groups (see B.5.2 and B.5.4);
 - revisions to claims about the system's benefits;
 - updates and changes in how the system works, as well as any necessary maintenance measures, including their frequency;
 - contact information;
 - educational materials for system use.
- 人為監管的需求；
 - 關於準確性和績效的資訊；
 - 衝擊評鑑中的相關資訊，包括潛在的利益和危害，特別是如果它們適用於特定背景或某些人口群體（參見 B.5.2 和 B.5.4）；
 - 系統利益聲明之修訂；
 - 系統運作方式的更新和變更，以及任何必要的維護措施，包括它們的頻率；
 - 聯繫資訊；
 - 系統使用的教育材料。

Criteria used by the organization to determine whether and what information is to be provided should be documented. Relevant criteria include but are not limited to the intended use and reasonably foreseeable misuse of the AI system, the expertise of the user and specific impact of the AI system.

Information can be provided to users in numerous ways, including documented instructions for use, alerts and other notifications built into the system itself, information on a web page, etc. Depending on which methods the organization uses to provide information, it should validate that the users have access to this information, and that the information provided is complete, up to date and accurate.

B.8.3 External reporting

Control

The organization should provide capabilities for interested parties to report adverse impacts of the system.

Implementation guidance

While the system operation should be monitored for reported issues and failures, the organization should also provide capabilities for users or other external parties to report adverse impacts (e.g. unfairness).

組織宜文件化用於決定是否以及提供哪些資訊的準則。相關準則包括但不限於人工智慧系統的預期用途和合理可預見的誤用、使用者的專業知識和人工智慧系統的特定影響。

資訊可以通過多種方式提供給使用者，包括文件化的使用說明、系統內置的警報和其他通知、網頁上的資訊等。根據組織用於提供資訊的方法，它宜驗證使用者是否能夠訪問這些資訊，以及提供的資訊是否完整、最新且準確。

B.8.3 外部通報

控制措施

組織宜提供讓關注方能夠通報人工智慧系統不良衝擊之機制。

實作指引

儘管系統運作宜監督所報告之議題和故障，組織亦宜提供能力讓使用者或其他外部方報告不良影響（如不公平性）。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

B.8.4 Communication of incidents

Control

The organization should determine and document a plan for communicating incidents to users of the system.

Implementation guidance

Incidents related to the AI system can be specific to the AI system itself, or related to information security or privacy (e.g. a data breach). The organization should understand its obligations around notifying users and other interested party about incidents, depending on the context in which the system operates. For example, an incident with an AI component that is part of a product that affects safety can have different notification requirements than other types of systems. Legal requirements (such as contracts) and regulatory activity can apply, which can specify requirements for:

- types of incidents that must be communicated;
- the timeline for notification;
- whether and which authorities must be notified;
- the details required to be communicated.

The organization can integrate incident response and reporting activities for AI into their broader organizational incident management activities, but should be aware of unique requirements related to AI systems, or individual components of AI systems (e.g. a PII data breach in training data for the system can have different reporting requirements related to privacy).

Other information

ISO/IEC 27001 and ISO/IEC 27701 provide additional details on incident management for security and privacy respectively.

B.8.5 Information for interested parties

Control

The organization should determine and document its obligations to reporting information about the AI system to interested parties.

B.8.4 事故溝通或傳達

控制措施

組織宜決定並文件化向系統使用者溝通或傳達事故的規劃。

實作指引

與人工智慧系統相關的事故可能是特定於人工智慧系統本身的，或與資訊安全或隱私相關的（如資料洩露）。組織宜根據系統運作的背景，了解其在通知使用者和其他關注方關於事故的義務。例如，影響安全性的產品中人工智慧組件的事故可能有不同的通知需求，而與其他類型系統的事故通知需求不同。法律需求（如合約）和監管活動可適用，這可註明以下需求：

- 必須傳達的事件類型；
- 通知的時間表；
- 是否以及必須通知哪些當局；
- 必須傳達的詳細資訊。

組織可以將人工智慧事故響應和報告活動整合到其更廣泛的組織事故管理活動中，但宜注意與人工智慧系統或人工智慧系統的個別組件相關的獨特要求（例如，系統訓練資料中的個人可識別資料洩露可能有與隱私相關的不同報告要求）。

其他資訊

ISO/IEC 27001 和 ISO/IEC 27701 分別提供了有關資安與隱私的事故管理的詳細資訊。

B.8.5 關注方資訊

控制措施

組織宜決定並文件化向關注方報告人工智慧系統資訊的義務。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Implementation guidance

In some cases, a jurisdiction can require information about the system to be shared with authorities such as regulators. Information can be reported to interested parties such as customers or regulatory authorities within the appropriate timeframe. The information shared can include, for example:

- technical system documentation, including, but not limited, to data sets for training, validation and testing as well as algorithmic choices justifications and verification and validation records;
- risks related to the system;
- results of impact assessments;
- logs and other system records.

The organization should understand their obligations in this respect and ensure that the appropriate information is shared with the correct authorities. Additionally, it is presupposed that the organization is aware of jurisdictional requirements related to information shared with law enforcement authorities.

B.9 Use of AI systems

B.9.1 Objective

To ensure that the organization uses AI systems responsibly and per organizational policies.

B.9.2 Processes for responsible use of AI systems

Control

The organization should define and document the processes for the responsible use of AI systems.

Implementation guidance

Depending on its context, the organization can have many considerations for determining whether to use a particular AI system. Whether the AI system is developed by the organization itself or sourced from a third party, the organization should be clear on what these considerations are and develop policies to address them. Some examples are:

- required approvals;
- cost (including for ongoing monitoring and maintenance);

實作指引

在某些情況下，司法管轄區可能要求與當局（如監管機構）共享系統資訊。資訊可以在適當的時間範圍內報告給關注方，如客戶或監管機構。共享的資訊可以包括，例如：

- 技術系統文件化，包括但不限於訓練、驗證和測試的資料集，以及演算法選擇的理由和驗證與確認記錄；
- 與系統相關的風險；
- 衝擊評鑑的結果；
- 日誌和其他系統記錄。

組織宜了解其在這方面的義務，並確保將適當的資訊共享給正確的當局。此外，預設組織了解與執法機構共享資訊的司法管轄要求。

B.9 人工智慧系統之使用

B.9.1 目標

確保組織遵循組織政策負責任地使用人工智慧系統。

B.9.2 負責任使用人工智慧系統之流程

控制措施

組織宜定義並文件化負責任使用人工智慧系統的流程。

實作指引

根據其背景，組織可以有許多考慮來決定是否使用特定的人工智慧系統。無論人工智慧系統是由組織自行開發還是來自第三方，組織宜清楚這些考量因素，並制定政策來處理它們。部分範例如：

- 被要求核可；
- 成本（包括持續監督和維護的成本）；

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

- approved sourcing requirements;
- legal requirements applicable to the organization.

Where the organization has accepted policies for the use of other systems, assets, etc., these policies can be incorporated if desired.

B.9.3 Objectives for responsible use of AI system

Control

The organization should identify and document objectives to guide the responsible use of AI systems.

Implementation guidance

The organization operating in different contexts can have different expectations and objectives for what constitutes the responsible development of AI systems. Depending on its context, the organization should identify its objectives related to responsible use. Some objectives include:

- fairness;
- accountability;
- transparency;
- explainability;
- reliability;
- safety;
- robustness and redundancy;
- privacy and security;
- accessibility.

Once defined, the organization should implement mechanisms to achieve its objectives within the organization. This can include determining if a third-party solution fulfils the organization's objectives or if an internally developed solution is applicable for the intended use. The organization should determine at which stages of the AI system life cycle meaningful human oversight objectives should be incorporated. This can include:

- 核可的採購要求；
- 適用於組織的法律要求。

如果組織已經接受了其他系統、資產等的使用政策，可以根據需要將這些政策納入其中。

B.9.3 負責任使用人工智慧系統之目標

控制措施

組織宜識別並文件化目標，以指導人工智慧系統的負責任使用。

實作指引

在不同背景下運作的組織對於什麼構成負責任的人工智慧系統開發可能有不同的期望和目標。根據其背景，組織宜識別與負責任使用相關的目標。部分目標如：

- 公平性；
- 當責性；
- 透明性；
- 可解釋性；
- 可靠性；
- 安全性；
- 穩健性與多備；
- 隱私與資安；
- 可及性。

一旦確定，組織宜在內部實施機制以達成這些目標。這可以包括確定第三方解決方案是否滿足組織的目標，或內部開發的解決方案是否適用於預期用途。組織宜決定在人工智慧系統生命週期的哪些階段宜納入具意義的人為監管目標。這可以包括：

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

— involving human reviewers to check the outputs of the AI system, including having authority to override decisions made by the AI system;

— ensuring that human oversight is included if required for acceptable use of the AI system according to instructions or other documentation associated with the intended deployment of the AI system;

— monitoring the performance of the AI system, including the accuracy of the AI system outputs;

— reporting concerns related to the outputs of the AI system and their impact to relevant interested parties;

— reporting concerns with changes in the performance or ability of the AI system to make correct outputs on the production data;

— considering whether automated decision-making is appropriate for a responsible approach to the use of an AI system and the intended use of the AI system.

The need for human oversight can be informed by the AI system impact assessments (see B.5). The personnel involved in human oversight activities related to the AI system should be informed of, trained out to satisfy human oversight objectives. When reporting performance issues, human oversight can augment automated monitoring.

Other information

Annex C provides examples of organizational objectives for managing risk, which can be useful in determining the objectives for AI system use.

B.9.4 Intended use of the AI system

Control

The organization should ensure that the AI system is used according to the intended uses of the AI system and its accompanying documentation.

Implementation guidance

The AI system should be deployed according to the instructions and other documentation associated with the AI system (see B.8.2). The deployment can require specific resources to support the deployment, including the need to ensure that human oversight is applied as required (see B.9.3).

— 涉及人為審查員檢查人工智慧系統的輸出，包括擁有覆蓋人工智慧系統決策的權限；

— 根據與人工智慧系統預期部署相關的說明或其他文件，如果需要人工智慧系統的可接受使用，確保包括人工監管；

— 監督人工智慧系統的性能，包括人工智慧系統輸出的準確性；

— 報告與人工智慧系統輸出及其對相關關注方的影響有關的問題；

— 報告人工智慧系統性能或在生產資料上正確輸出的能力發生變化的問題；

— 考慮自動化決策是否適合作為負責任使用人工智慧系統的方法以及人工智慧系統的預期用途。

人為監管的需求可以由人工智慧系統衝擊評鑑提供資訊 (參見 B.5)。參與與人工智慧系統相關的人為監管活動的員工宜了解、接受培訓並理解人工智慧系統的指導和其他文件以及他們所執行的職責，以滿足人為監管的目標。在報告性能問題時，人為監管可以增強自動化監督。

其他資訊

附錄 C 提供了管理風險的組織目標的範例，這對確定人工智慧系統使用的目標有幫助。

B.9.4 人工智慧系統之預期用途

控制措施

組織宜確保人工智慧系統根據其預期用途和隨附之文件化進行使用。

實作指引

人工智慧系統宜根據與人工智慧系統相關的指導和其他文件化進行部署 (參見 B.8.2)。部署可能需要特定資源來支持部署，包括需要確保按要要求應用人為監管 (參見 B.9.3)。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

It can be necessary that for acceptable use of the AI system, the data that the AI system is used on aligns with the documentation associated with the AI system to ensure that the AI system performance is accurate.

The operation of the AI system should be monitored (see B.6.2.6). Where the correct deployment of the AI system according to its associated instructions causes concern regarding the impact to relevant interested parties or the organization's legal requirements, the organization should communicate its concerns to the relevant personnel inside the organization as well as to any third-party suppliers of the AI system.

The organization should keep event logs or other documentation related to the deployment and operation of the AI system which can be used to demonstrate that the AI system is being used as intended or to help with communicating concerns related to the intended use of the AI system. The time period during which event logs and other documentation are kept depends on the intended use of the AI system, the organization's data retention policies and relevant legal requirements for data retention.

B.10 Third-party and customer relationships

B.10.1 Objective

To ensure that the organization understands its responsibilities and remains accountable, and risks are appropriately apportioned when third parties are involved at any stage of the AI system life cycle.

B.10.2 Allocating responsibilities

Control

The organization should ensure that responsibilities within their AI system life cycle are allocated between the organization, its partners, suppliers, customers and third parties.

Implementation guidance

In an AI system life cycle, responsibilities can be split between parties providing data, parties providing algorithms and models, parties developing or using the AI system and being accountable with regard to some or all interested parties. The organization should document all parties intervening in the AI system life cycle and their roles and determine their responsibilities.

為了確保人工智慧系統可接受之使用，人工智慧系統所使用的資料宜與人工智慧系統相關的文件化保持一致，以確保人工智慧系統性能的準確性。

宜監督人工智慧系統的運作（參見 B.6.2.6）。如果根據其相關指導正確部署人工智慧系統引起了對相關關注方或組織法律要求的影響的擔憂，組織宜將其擔憂傳達給組織內相關人員以及任何人工智慧系統的第三方供應商。

組織宜保留與人工智慧系統部署和運作相關的事件日誌或其他文件化，這些文件可用於證明人工智慧系統是按預期使用的，或有助於傳達與人工智慧系統預期用途相關的擔憂。事件日誌和其他文件化的保留時間取決於人工智慧系統的預期用途、組織的資料保留政策以及相關的資料保留法律要求。

B.10 第三方和客戶之關係

B.10.1 目標

確保組織瞭解其責任並承擔責任，當第三方參與人工智慧系統生命週期的任何階段時，適當地分配風險。

B.10.2 責任之分配

控制措施

組織宜確保在其人工智慧系統生命週期內的責任在組織、其合作夥伴、供應商、客戶和第三方之間進行分配。

實作指引

在人工智慧系統的生命週期中，責任可以分配給提供資料的單位、提供算法和模型的單位、開發或使用人工智慧系統的單位，以及對某些或所有關注方。組織宜文件化所有介入人工智慧系統生命週期的各方及其角色，並確定其責任。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Where the organization supplies an AI system to a third party, the organization should ensure that it takes a responsible approach to developing the AI system. See the controls and guidance in B.6. The organization should be able to provide the necessary documentation (see B.6.2.7 and B.8.2) for the AI system to relevant interested parties and to the third party that the organization is supplying the AI system to.

When processed data includes PII, responsibilities are usually split between PII processors and controllers. ISO/IEC 29100 provides further information on PII controllers and PII processors.

Where the privacy of PII is to be preserved, controls such as those described in ISO/IEC 27701 should be considered. Based on the organization's and AI system's data processing activities on PII and the organization's role in application and development of the AI system through their life cycle, the organization can take on the role of a PII controller (or joint PII controller), PII processor or both

B.10.3 Suppliers

Control

The organization should establish a process to ensure that its usage of services, products or materials provided by suppliers aligns with the organization's approach to the responsible development and use of AI systems.

Implementation guidance

Organizations developing or using an AI system can utilize suppliers in a number of ways, from sourcing datasets, machine learning algorithms or models, or other components of a system such as software libraries, to an entire AI system itself for use on its own or as part of another product (e.g. a vehicle).

Organizations should consider different types of suppliers, what they supply, and the varying level of risk this can pose to the system and organization as a whole in determining the selection of suppliers, the requirements placed on those suppliers, and the levels of ongoing monitoring and evaluation needed for the suppliers.

當組織向第三方提供人工智慧系統時，宜確保其採取負責任的方式開發人工智慧系統。參見 B.6 中的控制措施和指引。組織宜能夠向相關關注方以及向其提供人工智慧系統的第三方提供必要的文件化（參見 B.6.2.7 和 B.8.2）。

當處理的資料包含個人可識別資訊時，責任通常在個人可識別資訊處理者和控制者之間分配。ISO/IEC 29100 提供了有關個人可識別資訊控制者和個人可識別資訊處理者的更多資訊。

當需要保護個人可識別資訊的隱私時，宜考慮如 ISO/IEC 27701 中所描述的控制措施。根據組織和人工智慧系統在個人可識別資訊資料處理活動中的角色以及組織在人工智慧系統應用和開發中的角色，組織可以擔任個人可識別資訊控制者（或共同個人可識別資訊控制者）、個人可識別資訊處理者或兩者兼而有之。

B.10.3 供應商

控制措施

組織宜建立一個流程，以確保其使用供應商提供的服務、產品或材料符合組織對人工智慧系統負責任開發和使用的方法。

實作指引

開發或使用人工智慧系統的組織可以通過多種方式使用供應商，從採購資料集、機器學習演算法或模型，或系統的其他組件，如軟體函式庫，到整個人工智慧系統本身，無論是單獨使用還是作為其他產品的一部分（如車輛）。

組織宜考慮不同類型的供應商、他們提供的內容，以及這可能對系統和整個組織構成的不同級別的風險，從而確定供應商的選擇、對這些供應商的要求以及需要對供應商進行的持續監督和評估的級別。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Organizations should document how the AI system and AI system components are integrated into AI systems developed or used by the organization.

Where the organization considers that the AI system or AI system components from a supplier do not perform as intended or can result in impacts to individuals or groups of individuals, or both, and societies that are not aligned with the responsible approach to AI systems taken by the organization, the organization should require the supplier to take corrective actions. The organization can decide to work with the supplier to achieve this objective.

The organization should ensure that the supplier of an AI system delivers appropriate and adequate documentation related to the AI system (see B.6.2.7 and B.8.2).

B.10.4 Customers

Control

The organization should ensure that its responsible approach to the development and use of AI systems considers their customer expectations and needs.

Implementation guidance

The organization should understand customer expectations and needs when it is supplying a product or service related to an AI system (i.e. when it is itself a supplier). These can come in the form of requirements for the product or service itself during a design or engineering phase, or in the form of contractual requirements or general usage agreements. One organization can have many different types of customer relationships, and these can all have different needs and expectations.

The organization should particularly understand the complex nature of supplier and customer relationships and understand where responsibility lies with the provider of the AI system and where it lies with the customer, while still meeting needs and expectations.

For example, the organization can identify risks related to the use of its AI products and services by the customer and can decide to treat the identified risks by giving appropriate information to its customer, so that the customer can then treat the corresponding risks.

As an example of appropriate information, when an AI system is valid for a certain domain of use, the limits of the domain should be communicated to the customer. See B.6.2.7 and B.8.2.

組織宜記錄人工智慧系統和人工智慧系統組件如何整合到組織開發或使用的人工智慧系統中。

當組織認為來自供應商的人工智慧系統或人工智慧系統組件未按預期運作，或可能對個人或群體，以及對社會產生不符合組織對人工智慧系統負責任方法的影響時，組織宜要求供應商採取矯正措施。組織可以決定與供應商合作以實現這一目標。

組織宜確保人工智慧系統的供應商提供與人工智慧系統相關的適當且充分的文件化（參見 B.6.2.7 和 B.8.2）。

B.10.4 客戶

控制措施

組織宜確保其對人工智慧系統開發和使用的負責任方法考量到客戶的期望和需求。

實作指引

當組織向客戶提供與人工智慧系統相關的產品或服務（即當其本身為供應商）時，宜瞭解客戶的期望和需求。這些需求可能以設計或工程階段的產品或服務需求形式，或以合約要求或一般使用協議的形式出現。組織可能擁有多種不同類型的客戶關係，這些關係的需求和期望各不相同。

組織宜特別理解供應商和客戶關係的複雜性，並了解人工智慧系統提供者和客戶的責任所在，同時滿足需求和期望。

例如，組織可以識別與客戶使用其人工智慧產品和服務相關的風險，並可以決定通過向客戶提供適當的資訊來處理已識別的風險，從而使客戶能夠處理相應的風險。

作為合適資訊的一個例子，當人工智慧系統在某個特定領域內有效時，宜向客戶傳達該領域的限制。參見 B.6.2.7 和 B.8.2。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Annex C (informative)

Potential AI-related organizational objectives and risk sources

C.1 General

This annex outlines potential organizational objectives, risk sources and descriptions that can be considered by the organization when managing risks. This annex is not intended to be exhaustive or applicable for every organization. The organization should determine the objectives and risk sources that are relevant. ISO/IEC 23894 provides more detailed information on these objectives and risk sources, and their relationship to risk management. Evaluation of AI systems, initially, regularly and when warranted, provides evidence that an AI system is being assessed against organizational objectives.

C.2 Objectives

C.2.1 Accountability

The use of AI can change existing accountability frameworks. Where previously persons would be held accountable for their actions, their actions can now be supported by or based on the use of an AI system.

C.2.2 AI expertise

A selection of dedicated specialists with interdisciplinary skill sets and expertise in assessing, developing and deploying AI systems is needed.

C.2.3 Availability and quality of training and test data

AI systems based on ML need training, validation and test data in order to train and verify the systems for the intended behaviour.

C.2.4 Environmental impact

The use of AI can have positive and negative impacts on the environment.

C.2.5 Fairness

The inappropriate application of AI systems for automated decision-making can be unfair to specific persons or groups of persons.

附錄C (資訊性)

潛在與人工智慧相關的組織目標和風險來源

C.1 一般要求

本附錄概述於管理風險時，組織可以考慮的潛在組織目標、風險來源及其描述。本附錄並非旨在全面涵蓋所有可能性，也不適用於每個組織。組織宜決定相關的目標和風險來源。ISO/IEC 23894 提供了關於目標和風險來源的更詳細資訊，及其與風險管理的關係。對人工智慧系統進行初步、定期以及在必要時的評估，可以提供證據表明人工智慧系統是否正在根據組織目標進行評定。

C.2 目標

C.2.1 當責性

人工智慧的使用可能會改變現有的當責性框架。過去人們對自己的行為負責，而現在人們可能受到人工智慧系統的支持或基於人工智慧系統而行動。

C.2.2 人工智慧專業知識

需要選拔具備跨學科技能和專長的專門人才來評估、開發和部署人工智慧系統。

C.2.3 訓練和測試資料之可用性與品質

基於機器學習的人工智慧系統需要訓練、驗證和測試資料，以便對系統的預期行為進行訓練和驗證。

C.2.4 環境影響

人工智慧的使用對環境可能產生正面和負面的影響。

C.2.5 公平性

以不當的人工智慧系統應用進行自動化決策，可能對特定個人或群體造成不公平。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

C.2.6 Maintainability

Maintainability is related to the ability of the organization to handle modifications of the AI system in order to correct defects or adjust to new requirements.

C.2.7 Privacy

The misuse or disclosure of personal and sensitive data (e.g. health records) can have harmful effects on data subjects.

C.2.8 Robustness

In AI, robustness properties demonstrate the ability (or inability) of the system to have comparable performance on new data as on the data on which it was trained or the data of typical operations.

C.2.9 Safety

Safety relates to the expectation that a system does not, under defined conditions, lead to a state in which human life, health, property or the environment is endangered.

C.2.10 Security

In the context of AI and in particular with regard to AI systems based on ML approaches, new security issues should be considered beyond classical information and system security concerns.

C.2.11 Transparency and explainability

Transparency relates both to characteristics of an organization operating AI systems and to those systems themselves. Explainability relates to explanations of important factors influencing the AI system results that are provided to interested parties in a way understandable to humans.

C.3 Risk sources

C.3.1 Complexity of environment

When AI systems operate in complex environments, where the range of situation is broad, there can be uncertainty on the performance and therefore a source of risk (e.g. complex environment of autonomous driving).

C.2.6 可維護性

可維護性關係到組織處理人工智慧系統變更之能力，以矯正缺陷或依新需求進行調整。

C.2.7 隱私性

個人和敏感資料（如：健康紀錄）的誤用或洩露可能對資料主體產生有害影響。

C.2.8 穩健性

在人工智慧中，穩健性屬性證明系統在新資料上，具有與在其訓練資料或典型操作資料上相當的效能的能力（或缺乏之能力）。

C.2.9 安全性

安全性為系統在規定之情況下，不會導致人類生命、健康、財產或環境受到危害的預期擔憂。

C.2.10 資安

在人工智慧的背景下，特別是針對基於機器學習方法的人工智慧系統，宜考慮新的資安議題，而非僅傳統資訊和系統資安問題。

C.2.11 透明性和可解釋性

透明性既涉及運行人工智慧系統的組織之特性及系統本身。可解釋性則為向關注方提供的重要影響人工智慧系統結果的因素之說明，並以人類可以理解的方式提供這些解釋。

C.3 風險來源

C.3.1 環境的複雜性

當人工智慧系統在複雜環境中運行時，由於情境範圍廣泛，其性能可能存在不確定性，從而成為風險來源（例如，自動駕駛的複雜環境）。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

C.3.2 Lack of transparency and explainability

The inability to provide appropriate information to interested parties can be a source of risk (i.e. in terms of trustworthiness and accountability of the organization).

C.3.3 Level of automation

The level of automation can have an impact on various areas of concerns, such as safety, fairness or security.

C.3.4 Risk sources related to machine learning

The quality of data used for ML and the process used to collect data can be sources of risk, as they can impact objectives such as safety and robustness (e.g. due to issues in data quality or data poisoning).

C.3.5 System hardware issues

Risk sources related to hardware include hardware errors based on defective components or transferring trained ML models between different systems.

C.3.6 System life cycle issues

Sources of risk can appear over the entire AI system life cycle (e.g. flaws in design, inadequate deployment, lack of maintenance, issues with decommissioning).

C.3.7 Technology readiness

Risk sources can be related to less mature technology due to unknown factors (e.g. system limitations and boundary conditions, performance drift), but also due to the more mature technology due to technology complacency.

C.3.2 缺乏透明性和可解釋性

無法向關注方提供適當資訊可能成為風險來源（即在組織的可信性和當責性方面）。

C.3.3 自動化水平

自動化水平可能會影響諸多關注領域，如安全性、公平性或資安。

C.3.4 與機器學習相關的風險來源

用於機器學習的資料品質和資料收集過程可能是風險來源，因為它們可能影響安全性和穩健性等目標（例如，由於資料品質問題或資料汙染）。

C.3.5 系統硬體問題

與硬體相關的風險來源包括由於缺陷組件導致的硬體錯誤，或將訓練好的機器學習模型轉移到不同系統之間。

C.3.6 系統生命週期問題

風險來源可能出現在整個人工智慧系統生命週期中（例如，設計缺陷、不適當之部署、缺乏維護、停用問題）。

C.3.7 技術成熟度

風險來源可能與不夠成熟的技術相關，這是由於未知因素（例如系統限制和邊界條件、表現漂移）引起的，但也可能與較成熟的技術相關，這是由於技術上的自負而導致的。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

Annex D
(informative)

Use of the AI management system across domains
or sectors

D.1 General

This management system is applicable to any organization developing, providing or using products or services that utilize an AI system. Therefore, it is applicable potentially to a great variety of products and services, in different sectors, which are subject to obligations, good practices, expectations or contractual commitment towards interested parties. Examples of sectors are:

- health;
- defence;
- transport;
- finance;
- employment;
- energy.

Various organizational objectives (see Annex C for possible objectives) can be considered for the responsible development and use of an AI system. This document provides requirements and guidance from an AI technology specific view. For several of the potential objectives, generic or sector-specific management system standards exist. These management system standards consider the objective usually from a technology neutral point of view, while the AI management system provides AI technology specific considerations.

AI systems consist not only of components using AI technology, but can use a variety of technologies and components. Responsible development and use of an AI system therefore requires taking into account not only AI-specific considerations, but also the system as a whole with all the technologies and components that are used. Even for the AI technology specific part, other aspects besides AI specific considerations should be taken into account.

附件 D
(資訊性)

人工智慧管理系統在各領域或行業中的應用

D.1 一般要求

此管理系統適用於任何開發、提供或使用涉及人工智慧系統的產品或服務的組織。因此，它可以應用於各種不同的產品和服務，涵蓋不同的行業，這些行業需遵循針對關注方之義務、良好作法、期望或合約承諾。行業範例包括：

- 醫療保健；
- 國防；
- 交通；
- 金融；
- 就業；
- 能源。

可考量多樣化之組織目標（參見附錄 C 中之可能目標），以促進人工智慧系統的負責任開發和使用。本文件從人工智慧技術之特定角度提供要求和指引。對於部份潛在目標，則存在於一般或特定部門的管理體系標準。這些管理系統標準通常從技術中立的角度考慮目標，而人工智慧管理系統則提供人工智慧技術特定的考量。

人工智慧系統不僅僅由使用人工智慧技術的組件組成，它還可以使用多種技術和組件。因此，負責任之開發與使用人工智慧系統需要同時考慮人工智慧特定之因素和整個系統中的所有技術與組件。即使在人工智慧技術特定的部分，宜考慮其他方面，例如，作為一種資訊處理技術，資訊安全通常適用於人工智慧系統。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

For example, as AI is an information processing technology, information security applies generally to it. Objectives such as safety, security, privacy and environmental impact should be managed holistically and not separately for AI and the other components of the system. Integration of the AI management system with generic or sector-specific management system standards for relevant topics is therefore essential for responsible development and use of an AI system.

D.2 Integration of AI management system with other management system standards

When providing or using AI systems, the organization can have objectives or obligations related to aspects which are topics of other management system standards. These can include, for example, security, privacy, quality, respectively topics covered in ISO/IEC 27001, ISO/IEC 27701 and ISO 9001.

When providing, using or developing AI systems, potential relevant generic management system standards, but not limited to that, are:

— ISO/IEC 27001: In most contexts, security is key to achieving the objectives of the organization with the AI system. The way an organization pursues security objectives depends on its context and its own policies. If an organization identifies the need to implement an AI management system an information security management system in conformity with ISO/IEC 27001. Given that both ISO/IEC 27001 and the AI management systems use the high-level structure, their integrated use is facilitated and of great benefit for the organization. In this case, the way to implement controls which (partly) relate to information security in this document (see B.6.1.2) can be integrated with the organization's implementation of ISO/IEC 27001.

— ISO/IEC 27701: In many context and application domains, PII's are processed by AI systems. The organization can then comply with the applicable obligations for privacy and with its own policies and objectives. Similarly, as for ISO/IEC 27001, the organization can benefit from the integration of ISO/IEC 27701 with the AI management system. Privacy-related objectives and controls of the AI management system (see B.2.3 and B.5.4) can be integrated with the organization's implementation of ISO/IEC 27701.

像安全性、資安、隱私性和環境影響這些目標宜被統一管理，而不應該將人工智慧與系統中的其他組件分開處理。因此，將人工智慧管理系統與通用或特定行業的管理系統標準整合是人工智慧系統負責任開發和使用的關鍵。

D.2 AI管理系統與其他管理系統標準的整合

當提供或使用人工智慧系統時，組織可能有與其他管理系統標準主題相關的目標或義務。例如，這些主題可能包括資安、隱私、品質，分別涵蓋在 ISO/IEC 27001、ISO/IEC 27701 和 ISO 9001 中。

當提供、使用或開發人工智慧系統時，潛在相關的通用管理系統標準，包括但不限於此：

— ISO/IEC 27001：多數情況下，資安是實現組織人工智慧系統目標的關鍵。組織追求安全性目標的方式取決於其環境和自身的政策。如果組織確定需要實施一個符合 ISO/IEC 27001 的人工智慧管理系統或資訊安全管理系統。由於 ISO/IEC 27001 和人工智慧管理系統都採用高階架構，因此它們的整合使用可以促進人工智慧管理系統，並對組織有很大益處。在這種情況下，本文件中涉及部分資訊安全的控制措施（參見 B.6.1.2）可以與組織實施的 ISO/IEC 27001 進行整合。

— ISO/IEC 27701：在許多情境和應用領域中，人工智慧系統處理個人可識別資訊。組織因此可遵守適用的隱私權義務及自身的政策和目標。與 ISO/IEC 27001 類似，組織也可以受益於 ISO/IEC 27701 與人工智慧管理系統之整合。人工智慧管理系統的隱私相關目標和控制（參見 B.2.3 和 B.5.4）可以與組織實作的 ISO/IEC 27701 進行整合。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

— ISO 9001: For many organizations, conformity to ISO 9001 is a key sign that they are customer oriented and genuinely concerned about internal effectiveness. Independent conformity assessment to ISO 9001 facilitates business across organizations and inspires customer confidence in products or services. The level of customer's confidence in an organization or AI system can be highly reinforced when an AI management system is implemented jointly with ISO 9001 when AI technologies are involved. The AI management system can be complementary to the ISO 9001 requirements (risk management, software development, supply chain coherence, etc.) in helping the organization meet its objectives.

Besides the generic management system standards mentioned above, an AI management system can also be used jointly with a management system dedicated to a sector. For example, both ISO 22000 and an AI management system are relevant for an AI system that is used for food production, preparation and logistics. Another example is ISO 13485. The implementation of an AI management system can support requirements related to medical device software in ISO 13485 or requirements from other International Standards from the medical sector such as IEC 62304.

— ISO 9001：對於許多組織而言，符合 ISO 9001 是一個關鍵象徵，表明它們注重客戶導向並真正關心內部效能。通過 ISO 9001 的獨立合規性評估，可促進跨組織的業務往來，並增強客戶對產品或服務的信心。當涉及人工智慧技術時，當人工智慧管理系統與 ISO 9001 聯合實作時，客戶對組織或人工智慧系統的信心水平可能會大大提高。人工智慧管理系統可以補充 ISO 9001 的要求（風險管理、軟體開發、供應鏈協作等），幫助組織實現其目標。

除了上述的通用管理系統標準外，人工智慧管理系統還可以與專門針對某個行業的管理系統共同使用。例如，ISO 22000 和人工智慧管理系統對於用於食品生產、準備和物流的人工智慧系統都是相關的。另一個例子是 ISO 13485。人工智慧管理系統的實作可以支持 ISO 13485 中與醫療設備軟件相關的要求，或醫療領域其他國際標準（如 IEC 62304）的要求。

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

參考書目

- [1] ISO 8000-2, Data quality — Part 2: Vocabulary
- [2] ISO 9001, Quality management systems — Requirements
- [3] ISO 9241-210, Ergonomics of human-system interaction — Part 210: Human-centred design for interactive systems
- [4] ISO 13485, Medical devices — Quality management systems — Requirements for regulatory purposes
- [5] ISO 22000, Food safety management systems — Requirements for any organization in the food chain
- [6] IEC 62304, Medical device software — Software life cycle processes
- [7] ISO/IEC Guide 51, Safety aspects — Guidelines for their inclusion in standards
- [8] ISO/IEC TS 4213, Information technology — Artificial intelligence — Assessment of machine learning classification performance
- [9] ISO/IEC 5259 (all parts), Data quality for analytics and machine learning (ML)
- [10] ISO/IEC 5338, Information technology — Artificial intelligence — AI system life cycle process
- [11] ISO/IEC 17065, Conformity assessment — Requirements for bodies certifying products, processes and services
- [12] ISO/IEC 19944-1, Cloud computing and distributed platforms — Data flow, data categories and data use — Part 1: Fundamentals
- [13] ISO/IEC 23053, Framework for Artificial Intelligence (AI) Systems Using Machine Learning (ML)
- [14] ISO/IEC 23894, Information technology — Artificial intelligence — Guidance on risk management
- [15] ISO/IEC TR 24027, Information technology — Artificial intelligence (AI) — Bias in AI systems and AI aided decision making
- [16] ISO/IEC TR 24029-1, Artificial Intelligence (AI) — Assessment of the robustness of neural networks — Part 1: Overview
- [17] ISO/IEC TR 24368, Information technology — Artificial intelligence — Overview of ethical and societal concerns
- [18] ISO/IEC 25024, Systems and software engineering — Systems and software Quality Requirements and Evaluation (SQuARE) — Measurement of data quality
- [19] ISO/IEC 25059, Software engineering — Systems and software Quality Requirements and Evaluation (SQuARE) — Quality model for AI systems
- [20] ISO/IEC 27000:2018, Information technology — Security techniques — Information security management systems — Overview and vocabulary
- [21] ISO/IEC 27701, Security techniques — Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management — Requirements and guidelines
- [22] ISO/IEC 27001, Information security, cybersecurity and privacy protection — Information security management systems — Requirements
- [23] ISO/IEC 29100, Information technology — Security techniques — Privacy framework
- [24] ISO 31000:2018, Risk management — Guidelines [25] ISO 37002, Whistleblowing management systems — Guidelines
- [26] ISO/IEC 38500:2015, Information technology — Governance of IT for the organization

本標準中文翻譯僅供讀者參考，各項原義應當以英文為唯一詮釋依據

[27] ISO/IEC 38507, Information technology — Governance of IT — Governance implications of the use of artificial intelligence by organizations

[28] Lifecycle D.D.I. 3.3, 2020-04-15. Data Documentation Initiative (DDI) Alliance. [viewed on 2022- 02-19]. Available at: <https://ddialliance.org/Specification/DDI-Lifecycle/3.3/>

[29] Risk Framework N.I.S.T.-A.I. 1.0, 2023-01-26. National Institute of Technology (NIST) [viewed on 2023-04-17] <https://www.nist.gov/itl/ai-risk-management-framework>

訓練專用 禁止翻印